HỌC PHẦN: CÁC VẤN ĐỀ HIỆN ĐẠI CỦA CÔNG NGHỆ PHẦN MỀM (DHIT20)

HỒ SƠ DỰ ÁN
UNICLUB - HỆ THỐNG QUẢN LÝ CÂU LẠC BỘ SINH VIÊN VÀ TỰ ĐỘNG HÓA CI/CD BẰNG GITHUB ACTIONS

Bản cụ thể hóa toàn bộ công việc: từ Project Charter, Backlog,
đặc tả yêu cầu, thiết kế, kiểm thử, tự động hóa CI/CD đến bảo vệ

Nhóm sinh viên:

Nguyễn Ngọc Hoa - 2374820065 - Tester
Nguyễn Phương Linh - 2374820116 - Trưởng nhóm (PM)
Đỗ Thị Thơ - 2374820180 - BA
Lưu Hữu Phát - 2374820143 - Dev kiêm phụ trách CI/CD (DevOps)

0. Vì sao có tài liệu này

Tài liệu này được xây dựng nhằm mô tả chi tiết và cụ thể hóa toàn bộ quá trình lập kế hoạch, phân tích yêu cầu, thiết kế, phát triển và tự động hóa quy trình tích hợp/triển khai (CI/CD) cho dự án UniClub - hệ thống quản lý câu lạc bộ sinh viên. Nội dung tài liệu đóng vai trò là hồ sơ quản lý dự án xuyên suốt, giúp nhóm phát triển theo dõi tiến độ, phân chia công việc, đảm bảo chất lượng mã nguồn và trình bày quy trình DevOps thực tế trước Hội đồng giảng viên.

Ghi chú: khung cấu trúc của hồ sơ này được kế thừa từ một mẫu hồ sơ dự án tham khảo của học phần, và được biên soạn lại toàn bộ theo đề tài quản lý câu lạc bộ sinh viên kết hợp CI/CD.

A. Project Charter - Hồ sơ khởi động dự án

Mục	Nội dung
Tên dự án	UniClub - Hệ thống Quản lý Câu lạc bộ Sinh viên và Tự động hóa CI/CD bằng GitHub Actions
Vấn đề cần giải quyết	Ban chủ nhiệm câu lạc bộ hiện quản lý hội viên, sự kiện và điểm danh thủ công qua Excel/Zalo, dẫn đến sai sót, khó tổng hợp báo cáo và không theo dõi được lịch sử tham gia của từng hội viên. Đồng thời, nhóm phát triển cần một quy trình phát triển phần mềm chuyên nghiệp, trong đó mã nguồn được kiểm thử và triển khai tự động thay vì thao tác thủ công dễ sai sót.
Mục tiêu dự án	Xây dựng hệ thống web UniClub hỗ trợ quản lý toàn diện câu lạc bộ: hồ sơ hội viên, cơ cấu Ban/Bộ phận, chức vụ và nhiệm kỳ; tiếp nhận và xét duyệt đơn gia nhập; quản lý sự kiện, lịch hoạt động, đăng ký và điểm danh; đăng bài viết/thông báo; Dashboard thống kê và báo cáo; phản hồi sau sự kiện. Song song đó, xây dựng pipeline CI/CD bằng GitHub Actions để tự động build, kiểm thử, kiểm tra chất lượng mã nguồn, quét dependency và triển khai lên staging.
Người dùng chính	(1) Hội viên (Sinh viên) - quản lý hồ sơ, gửi đơn gia nhập, xem lịch/sự kiện, đăng ký, điểm danh và phản hồi. (2) Trưởng ban chuyên môn - quản lý hoạt động và thành viên thuộc ban mình theo phạm vi được cấp quyền. (3) Ban chủ nhiệm/Admin - quản lý toàn bộ CLB, cơ cấu tổ chức, nhiệm kỳ, hội viên, sự kiện, nội dung và báo cáo. (4) Super Admin - quản lý tài khoản quản trị và cấu hình phân quyền. (5) GitHub Actions - tác nhân hệ thống tự động build, test, kiểm tra chất lượng và triển khai.
Phạm vi MVP (trong học kỳ)	Đăng ký/đăng nhập; quản lý vai trò; quản lý Ban/Bộ phận, chức vụ và nhiệm kỳ; gửi và duyệt đơn gia nhập CLB; xem danh sách sự kiện; tìm kiếm/lọc; lịch hoạt động dạng tháng/tuần; đăng ký tham gia; điểm danh QR; lịch sử tham gia; trang quản trị CRUD

Mục	Nội dung
	hội viên/sự kiện; bài viết/thông báo; Dashboard nâng cao và xuất báo cáo; Audit Log; pipeline CI gồm build + unit test + code quality + dependency scan; pipeline CD gồm package WAR + deploy staging + health check + smoke test.
Ngoài phạm vi (Out of scope)	Thanh toán/quản lý quỹ câu lạc bộ qua cổng ngân hàng thật; tích hợp điểm rèn luyện với hệ thống của trường; ứng dụng di động dạng native (chỉ làm web-app); triển khai CD lên môi trường production thật có tên miền và chứng chỉ SSL (chỉ demo trên môi trường staging nội bộ nhóm).
Mô hình phát triển	Agile/Scrum rút gọn - 3 sprint, mỗi sprint khớp với một mốc nộp Bài tập lớn/Đồ án (tuần 4, 7, 10), áp dụng kèm quy trình Continuous Integration/Continuous Delivery ngay từ Sprint 1.
Công cụ sử dụng	Git/GitHub (quản lý mã nguồn và Pull Request), GitHub Actions (tự động hóa CI/CD), Maven (quản lý build & thư viện Java), JUnit 5 (kiểm thử tự động), MySQL (cơ sở dữ liệu), StarUML (thiết kế sơ đồ Use Case, ERD), NetBeans/VS Code (môi trường phát triển) và Apache Tomcat (máy chủ ứng dụng web) chạy mã nguồn Java Servlet/JSP.

B. Product Backlog chi tiết

Backlog được nhóm theo 11 Epic (nhóm chức năng lớn). Mức ưu tiên dùng thang MoSCoW: Phải có (bắt buộc cho MVP), Nên có (quan trọng nhưng có thể lùi), Có thể có (làm nếu còn thời gian). Điểm ước lượng (Story Point) theo thang 1-5, phản ánh độ phức tạp tương đối, không phải số giờ cụ thể.

Epic 1 - Quản lý tài khoản & phân quyền hội viên

Đối với hội viên

Mã	User Story	Ưu tiên	Điểm	Sprint
US01	Là sinh viên, tôi muốn đăng ký tài khoản hội viên bằng email và mật khẩu, để có thể tham gia sinh hoạt và theo dõi hoạt động của câu lạc bộ.	Phải có	2	Sprint 1
US02	Là hội viên, tôi muốn đăng nhập bằng tài khoản đã đăng ký, để truy cập vào hệ thống quản lý câu lạc bộ.	Phải có	1	Sprint 1
US03	Là hội viên, tôi muốn cập nhật thông tin cá nhân như họ tên, lớp, khoa và số điện thoại, để Ban chủ nhiệm liên hệ khi cần.	Nên có	1	Sprint 2
US04	Là hội viên, tôi muốn xem lại lịch sử các hoạt động mình đã tham gia, để theo dõi quá trình đóng góp cho câu lạc bộ.	Nên có	2	Sprint 2

Đối với Ban chủ nhiệm CLB

Mã	User Story	Ưu tiên	Điểm	Sprint
US05	Là Ban chủ nhiệm, tôi muốn xem danh sách toàn bộ hội viên đang hoạt động, để nắm được quy mô và cơ cấu câu lạc bộ.	Phải có	2	Sprint 2
US06	Là Ban chủ nhiệm, tôi muốn duyệt đơn xin gia nhập câu lạc bộ của sinh viên mới, để kiểm soát chất lượng thành viên.	Phải có	2	Sprint 1
US07	Là Ban chủ nhiệm, tôi muốn khóa hoặc mở khóa tài khoản hội viên vi phạm nội quy, để duy trì kỷ luật sinh hoạt.	Nên có	2	Sprint 2

Mã	User Story	Ưu tiên	Điểm	Sprint
US08	Là Ban chủ nhiệm, tôi muốn phân quyền tài khoản (Hội viên / Trưởng ban chuyên môn / Ban chủ nhiệm), để phân cấp quản lý rõ ràng.	Nên có	2	Sprint 2

Epic 2 - Quản lý sự kiện & hoạt động

Mã	User Story	Ưu tiên	Điểm	Sprint
US09	Là hội viên, tôi muốn xem danh sách sự kiện sắp diễn ra theo loại hình (Học thuật, Tình nguyện, Giải trí...), để lựa chọn hoạt động phù hợp.	Phải có	2	Sprint 1
US10	Là hội viên, tôi muốn tìm kiếm sự kiện theo tên hoặc chủ đề, để nhanh chóng tìm hoạt động mình quan tâm.	Phải có	2	Sprint 1
US11	Là hội viên, tôi muốn xem chi tiết sự kiện gồm thời gian, địa điểm, số chỗ còn nhận đăng ký và mô tả, để quyết định có tham gia hay không.	Phải có	3	Sprint 1
US12	Là Ban chủ nhiệm, tôi muốn tạo, sửa và ẩn sự kiện, để cập nhật kế hoạch hoạt động của câu lạc bộ.	Phải có	3	Sprint 2
US13	Là Ban chủ nhiệm, tôi muốn cập nhật số chỗ còn nhận đăng ký cho từng sự kiện, để thông tin hiển thị luôn chính xác.	Phải có	2	Sprint 2

Epic 3 - Đăng ký tham gia & Điểm danh (Hội viên)

Mã	User Story	Ưu tiên	Điểm	Sprint
US14	Là hội viên, tôi muốn đăng ký tham gia sự kiện trong giới hạn số chỗ còn lại, để chắc chắn có một suất tham dự.	Phải có	3	Sprint 2
US15	Là hội viên, tôi muốn chọn hình thức tham gia (Trực tiếp / Trực tuyến) khi đăng ký, để phù hợp với điều kiện cá nhân.	Phải có	2	Sprint 2
US16	Là hội viên, tôi muốn hủy đăng ký tham gia khi sự kiện chưa diễn ra, để nhường chỗ cho hội viên khác nếu không thể tham dự.	Nên có	2	Sprint 2
US17	Là hội viên, tôi muốn xem trạng thái đăng ký của mình (Chờ duyệt, Đã duyệt, Đã điểm danh), để theo dõi tiến trình tham gia.	Nên có	2	Sprint 2
US18	Là hội viên, tôi muốn tự điểm danh bằng mã QR khi có mặt tại sự kiện, để xác nhận tham dự nhanh chóng.	Nên có	1	Sprint 2

Epic 4 - Điểm danh & Thống kê tham dự (Ban chủ nhiệm)

Mã	User Story	Ưu tiên	Điểm	Sprint
US19	Là Ban chủ nhiệm, tôi muốn quét mã QR hoặc xác nhận thủ công điểm danh cho từng hội viên tại sự kiện, để ghi nhận tham dự chính xác.	Phải có	3	Sprint 2
US20	Là Ban chủ nhiệm, tôi muốn xem thống kê điểm danh theo từng sự kiện và tỷ lệ tham gia, để đánh giá mức độ thu hút của hoạt động.	Nên có	1	Sprint 3

Epic 5 - Quản lý đăng ký tham gia (Ban chủ nhiệm)

Mã	User Story	Ưu tiên	Điểm	Sprint
US21	Là Ban chủ nhiệm, tôi muốn xem danh sách đăng ký tham gia mới theo thời gian thực, để chuẩn bị hậu cần cho sự kiện.	Phải có	3	Sprint 2
US22	Là Ban chủ nhiệm, tôi muốn duyệt hoặc từ chối đăng ký tham gia kèm lý do (ví dụ: hết chỗ), để hội viên nắm được kết quả.	Phải có	1	Sprint 3
US23	Là Ban chủ nhiệm, tôi muốn cập nhật trạng thái xử lý đăng ký (Chờ duyệt, Đã duyệt, Từ chối), để hội viên theo dõi được tiến độ.	Phải có	2	Sprint 2

Epic 6 - Bài viết, Thông báo & Dashboard báo cáo

Mã	User Story	Ưu tiên	Điểm	Sprint
US24	Là Ban chủ nhiệm, tôi muốn đăng bài viết giới thiệu hoạt động câu lạc bộ lên trang tin, để quảng bá hình ảnh và thu hút hội viên mới.	Nên có	2	Sprint 3
US25	Là Ban chủ nhiệm, tôi muốn gửi thông báo đến toàn thể hội viên hoặc một nhóm hội viên cụ thể, để truyền đạt thông tin kịp thời.	Nên có	2	Sprint 3
US26	Là Ban chủ nhiệm, tôi muốn xem Dashboard tổng quan (tổng hội viên, tổng sự kiện, tỷ lệ điểm danh trung bình) và xuất báo cáo hoạt động theo kỳ, để tổng kết và báo cáo giảng viên phụ trách.	Nên có	3	Sprint 3

Epic 7 - Phản hồi & đánh giá sau sự kiện

Mã	User Story	Ưu tiên	Điểm	Sprint
US27	Là hội viên, tôi muốn viết phản hồi và chấm điểm (sao) cho sự kiện đã tham gia, để chia sẻ trải nghiệm và góp ý cho Ban chủ nhiệm.	Có thể có	2	Sprint 3

Epic 8 - Quản lý cơ cấu CLB, Ban/Bộ phận, Chức vụ & Nhiệm kỳ

Mã User Story	User Story	Ưu tiên	Điểm	Sprint
US28	Là Ban chủ nhiệm, tôi muốn tạo, sửa, ẩn các Ban/Bộ phận của CLB (Truyền thông, Học thuật, Sự kiện, Đối ngoại...), để tổ chức nhân sự rõ ràng.	Phải có	3	Sprint 2
US29	Là Ban chủ nhiệm, tôi muốn quản lý chức vụ (Chủ nhiệm, Phó chủ nhiệm, Trưởng ban, Phó ban, Thành viên), để phân cấp trách nhiệm rõ ràng.	Phải có	2	Sprint 2
US30	Là Ban chủ nhiệm, tôi muốn quản lý nhiệm kỳ và phân công hội viên vào Ban/chức vụ theo thời gian, để theo dõi lịch sử cơ cấu CLB.	Phải có	3	Sprint 2

Epic 9 - Đăng ký gia nhập CLB

Mã User Story	User Story	Ưu tiên	Điểm	Sprint
US31	Là sinh viên, tôi muốn gửi đơn đăng ký gia nhập CLB kèm thông tin cá nhân và lý do tham gia, để Ban chủ nhiệm xem xét.	Phải có	2	Sprint 2
US32	Là Ban chủ nhiệm, tôi muốn duyệt hoặc từ chối đơn gia nhập kèm lý do,	Phải có	2	Sprint 2

	để kiểm soát thành viên mới.			
US33	Là sinh viên, tôi muốn xem trạng thái và lịch sử xử lý đơn gia nhập, để biết kết quả xét duyệt.	Nên có	1	Sprint 3

Epic 10 - Lịch hoạt động & Dashboard nâng cao

Mã User Story	User Story	Ưu tiên	Điểm	Sprint
US34	Là hội viên, tôi muốn xem lịch hoạt động theo tháng/tuần và theo loại sự kiện, để dễ dàng lập kế hoạch tham gia.	Nên có	2	Sprint 3
US35	Là Ban chủ nhiệm, tôi muốn xem Dashboard về hội viên, sự kiện, đăng ký và tỷ lệ tham dự, để đánh giá hiệu quả hoạt động CLB.	Phải có	3	Sprint 3
US36	Là Ban chủ nhiệm, tôi muốn xem Top hội viên tích cực và Top sự kiện có tỷ lệ tham dự cao, để đánh giá mức độ gắn kết.	Nên có	2	Sprint 3

Epic 11 - Bảo mật, Audit Log & Chất lượng triển khai

Mã User Story	User Story	Ưu tiên	Điểm	Sprint
US37	Là Admin, tôi muốn hệ thống ghi lại các thao tác quan trọng (tạo/sửa/ẩn sự kiện, duyệt thành viên, phân quyền), để truy vết khi cần.	Phải có	2	Sprint 3
US38	Là hệ thống, tôi muốn kiểm tra dependency và chất lượng mã nguồn trong CI, để phát hiện sớm lỗi và rủi ro trước khi merge.	Nên có	2	Sprint 3
US39	Là hệ thống, tôi muốn thực hiện health check và smoke test sau deploy, để phát hiện bản triển khai lỗi trước khi kết thúc pipeline.	Nên có	2	Sprint 3

Tổng cộng 39 User Story - trong đó các User Story mở rộng tập trung vào cơ cấu tổ chức, đăng ký gia nhập, lịch hoạt động, Dashboard nâng cao, Audit Log và chất lượng CI/CD. Nhóm cần ưu tiên hoàn thành các mục "Phải có" để đảm bảo MVP trọn vẹn.

C. Kế hoạch công việc theo Sprint (WBS)

Ba sprint khớp đúng với ba mốc nộp Bài tập lớn trong đề cương học phần (tuần 4, 7, 10), song song với việc xây dựng và mở rộng dần pipeline CI/CD.

Sprint 0 - Chuẩn bị & Đặc tả (Tuần 1-4)

Công việc	Phụ trách	Ước tính	Kết quả đầu ra
Thành lập nhóm, phân công vai trò (PM, BA, Dev, Tester)	Cả nhóm	1 giờ	Danh sách phân vai dự án
Viết Project Charter	Nguyễn Phương Linh (PM)	2 giờ	Mục A của hồ sơ

Công việc	Phụ trách	Ước tính	Kết quả đầu ra
Khảo sát nhu cầu (phỏng vấn 3-5 hội viên CLB thật + Google Form khảo sát thói quen tham gia hoạt động)	Đỗ Thị Thơ (BA)	3 giờ	Kết quả khảo sát nhu cầu
Viết Product Backlog & phân Epic/User Story	Đỗ Thị Thơ (BA) + PM	4 giờ	Mục B của hồ sơ
Thiết kế Use Case, ERD và Class Diagram sơ bộ bằng StarUML	Lưu Hữu Phát (Dev)	4 giờ	Mục E, F của hồ sơ
Khởi tạo repository trên GitHub, thiết lập nhánh main/develop, cấu hình Branch Protection Rule	Lưu Hữu Phát (Dev)	2 giờ	Repository GitHub sẵn sàng
Viết workflow GitHub Actions CI cơ bản (build Maven + chạy JUnit) và kiểm tra chạy thử	Lưu Hữu Phát (Dev)	3 giờ	File .github/workflows/ci.yml chạy thành công

Sprint 1 - Xây dựng nền tảng & Danh mục sự kiện (Tuần 5)

Công việc	Phụ trách	Ước tính	Kết quả đầu ra
Dựng khung dự án Java Servlet/JSP + Maven, kết nối MySQL	Lưu Hữu Phát (Dev)	4 giờ	Base project chạy được trên Tomcat
Xây dựng chức năng Đăng ký/Đăng nhập/Phân quyền (US01, US02, US06)	Lưu Hữu Phát (Dev)	6 giờ	Module Xác thực hoạt động
Xây dựng chức năng xem/tìm kiếm/lọc sự kiện (US09, US10, US11)	Lưu Hữu Phát (Dev)	6 giờ	Trang danh sách & chi tiết sự kiện
Viết Unit Test cho module Xác thực và Sự kiện (JUnit)	Nguyễn Ngọc Hoa (Tester)	3 giờ	Test case tự động chạy trong CI
Tạo Pull Request cho từng nhánh feature, review chéo trước khi merge vào develop	Cả nhóm Dev	2 giờ	Lịch sử Pull Request trên GitHub
Theo dõi kết quả GitHub Actions CI trên từng Pull Request, sửa lỗi build nếu có	Lưu Hữu Phát (Dev)	2 giờ	Toàn bộ PR có trạng thái CI PASS

Sprint 2 - Đăng ký tham gia, Điểm danh & Quản trị (Tuần 6-7)

Công việc	Phụ trách	Ước tính	Kết quả đầu ra
Xây dựng chức năng đăng ký tham gia sự kiện & hủy đăng ký (US14-US17)	Lưu Hữu Phát (Dev)	6 giờ	Module Đăng ký tham gia
Xây dựng chức năng điểm danh bằng mã QR (hội viên tự điểm danh và Admin xác nhận) (US18, US19)	Lưu Hữu Phát (Dev)	6 giờ	Module Điểm danh QR
Xây dựng trang quản trị: quản lý hội viên, duyệt đăng ký, CRUD sự kiện (US05, US12, US13, US21-US23)	Lưu Hữu Phát (Dev)	6 giờ	Trang Admin Dashboard cơ bản
Thiết kế và triển khai workflow CD (đóng gói file WAR, tự động triển khai lên Tomcat môi trường staging khi merge vào main)	Lưu Hữu Phát (Dev)	4 giờ	File .github/workflows/cd.yml, hệ thống tự cập nhật sau khi merge
Viết Test Case cho các luồng đăng ký, điểm danh, quản trị	Nguyễn Ngọc Hoa (Tester)	5 giờ	Bộ Test Case Sprint 2 (Mục G)

Công việc	Phụ trách	Ước tính	Kết quả đầu ra
Thực thi kiểm thử thủ công song song trên môi trường staging vừa được CD tự động triển khai	Nguyễn Ngọc Hoa (Tester)	4 giờ	Bug log Sprint 2
Sửa lỗi phát hiện qua kiểm thử (Bug fixing)	Lưu Hữu Phát (Dev) + Cả nhóm	4 giờ	Bug log đã đóng

Sprint 3 - Bài viết, Thông báo, Dashboard & Hoàn thiện CI/CD (Tuần 8-10)

Công việc	Phụ trách	Ước tính	Kết quả đầu ra
Xây dựng chức năng đăng bài viết, gửi thông báo (US24, US25)	Lưu Hữu Phát (Dev)	5 giờ	Module Bài viết/Thông báo
Xây dựng Dashboard thống kê & xuất báo cáo hoạt động theo kỳ (US20, US26)	Lưu Hữu Phát (Dev)	5 giờ	Trang Dashboard & Báo cáo
Xây dựng chức năng phản hồi/đánh giá sau sự kiện (US27)	Lưu Hữu Phát (Dev)	3 giờ	Module Phản hồi
Bổ sung Test Case CI/CD (kiểm tra PR bị chặn khi CI fail, kiểm tra CD tự động deploy) và chạy Regression Test toàn hệ thống	Nguyễn Ngọc Hoa (Tester)	5 giờ	Test Report hoàn chỉnh (Mục G)
Gắn huy hiệu (badge) trạng thái CI/CD vào README của repository	Lưu Hữu Phát (Dev)	1 giờ	README hiển thị badge Build Passing
Sửa lỗi phát hiện qua kiểm thử (Bug fixing)	Lưu Hữu Phát (Dev) + Cả nhóm	4 giờ	Bug log đã đóng
Chuẩn bị Slide báo cáo, Kịch bản Demo (bao gồm demo trực tiếp GitHub Actions) & Tổng kết hồ sơ	Nguyễn Phương Linh (PM)	3 giờ	Slide & Kịch bản Demo Day (Mục H)

→ Kết quả bàn giao: Bài tập lớn đợt 3 - nộp tuần 10; báo cáo và bảo vệ vào buổi Demo Day cuối kỳ, có demo trực tiếp pipeline CI/CD.

C.1. Công việc bổ sung cho phạm vi mở rộng

Công việc bổ sung	Phụ trách	Ước tính	Kết quả đầu ra
Thiết kế module Ban/Bộ phận, Chức vụ và Nhiệm kỳ	BA + Dev	4 giờ	ERD/Class Diagram và CRUD cơ cấu CLB
Xây dựng gửi/duyệt đơn gia nhập CLB (US31-US33)	Dev + BA	5 giờ	Module Membership Request
Xây dựng Calendar tháng/tuần và bộ lọc hoạt động	Dev	4 giờ	Trang Lịch hoạt động
Nâng cấp Dashboard và báo cáo KPI hoạt động	Dev + Tester	4 giờ	Dashboard biểu đồ + báo cáo
Bổ sung Audit Log và kiểm soát quyền theo role	Dev	4 giờ	AuditLog + Authorization Filter
Tích hợp code quality/dependency scan và health check vào CI/CD	Dev/DevOps	4 giờ	Workflow CI/CD mở rộng
Bổ sung test case cho tính năng mở rộng và bảo mật	Tester	5 giờ	Test Report cập nhật

D. Bảng quản lý rủi ro

STT	Rủi ro	Khả năng	Ảnh hưởng	Phương án ứng phó
1	Nút thắt tiến độ do tải công việc lập trình dồn vào một Dev chính (Single Point of Failure)	Cao	Cao	BA và Tester hỗ trợ cắt giao diện HTML/CSS tĩnh; PM theo dõi tiến độ theo ngày để kịp thời hỗ trợ Dev tháo gỡ khó khăn kỹ thuật.
2	Thành viên bận lịch thi / đồ án môn học khác trong kỳ	Cao	Trung bình	Họp nhóm cố định 1 buổi/tuần từ Sprint 0; phân chia khối lượng công việc rõ ràng theo mốc (deadline) và có nhật ký theo dõi tiến độ.
3	Khó khăn khi cài đặt môi trường và làm quen công nghệ mới (Java Servlet/JSP, Maven, Apache Tomcat, MySQL, GitHub Actions)	Trung bình	Cao	Dành 2-3 ngày đầu Sprint 1 để Dev nghiên cứu tài liệu, dựng khung dự án mẫu (Base Project) và chạy thử workflow GitHub Actions cơ bản trước khi viết code chính thức.
4	Thay đổi yêu cầu tính năng vượt quá phạm vi dự án (Scope Creep)	Trung bình	Trung bình	Khóa (Freeze) Product Backlog sau khi hoàn thành Sprint 0; các yêu cầu phát sinh mới (như tích hợp điểm rèn luyện, ví điện tử quỹ CLB) chuyển vào nhóm "Có thể có" cho các phiên bản sau.
5	Pipeline CI/CD thất bại do sai cấu hình phiên bản JDK/Maven giữa máy cá nhân và GitHub Actions runner	Trung bình	Trung bình	Thống nhất phiên bản công cụ ngay từ đầu (JDK 17, Maven 3.9); khai báo tường minh phiên bản trong file pom.xml và trong workflow YAML để môi trường CI khớp với môi trường local.
6	Mất mát mã nguồn hoặc cơ sở dữ liệu do không sao lưu định kỳ	Thấp	Rất cao	Commit và Push code lên GitHub tối thiểu 1 lần/ngày; workflow CI tự động kiểm tra build ở mỗi lần push; xuất (export) file dữ liệu MySQL backup định kỳ lên Google Drive của nhóm.
7	Không đủ thời gian kiểm thử kỹ lưỡng trước mốc nộp Bài tập lớn / Bảo vệ	Cao	Cao	Tester thiết kế kịch bản test case song song ngay từ Sprint 1 dựa trên Use Case; GitHub Actions tự động chạy lại toàn bộ unit test ở mỗi Pull Request để phát hiện lỗi hồi quy sớm.
8	Truy cập trái phép do cấu hình phân quyền không đúng	Trung bình	Cao	Áp dụng Authorization Filter, phân quyền theo role, test truy cập trực tiếp /admin và review quyền trước khi merge.
9	Lộ thông tin bí mật trong repository (DB password, secret)	Thấp	Rất cao	Dùng GitHub Secrets/environment variables; không commit secret; rà soát .gitignore và lịch sử commit.

E. ĐẶC TẢ YÊU CẦU CHI TIẾT

E.1. Danh sách tác nhân (Actors)

Tác nhân (Actor)	Vai trò trong hệ thống UniClub
Hội viên (Sinh viên)	Đăng ký, đăng nhập tài khoản; xem danh sách sự kiện; tìm kiếm & lọc sự kiện theo loại hình; xem chi tiết sự kiện; đăng ký tham gia & chọn hình thức tham gia (Trực tiếp/Trực tuyến); tự điểm danh bằng mã QR; theo dõi lịch sử tham gia; hủy đăng ký khi chưa diễn ra; viết phản hồi/đánh giá sau sự kiện.
Ban chủ nhiệm CLB (Admin)	Quản lý hội viên (duyệt đơn gia nhập, khóa/mở khóa, phân quyền); quản lý sự kiện (thêm/sửa/ẩn); tiếp nhận, duyệt hoặc từ chối đăng ký tham gia; điểm danh thủ công tại sự kiện; đăng bài viết & gửi thông báo; xem Dashboard thống kê và xuất báo cáo hoạt động.

Tác nhân (Actor)	Vai trò trong hệ thống UniClub
Hệ thống GitHub Actions (Tác nhân hệ thống)	Tự động kiểm tra (build và chạy Unit Test) mã nguồn mỗi khi có Pull Request hoặc Push; tự động đóng gói và triển khai (deploy) ứng dụng lên môi trường staging khi mã nguồn được merge vào nhánh main.
Trưởng ban chuyên môn	Quản lý thành viên và hoạt động thuộc Ban được phân quyền; tạo/cập nhật hoạt động nội bộ; xem thống kê phạm vi Ban.
Super Admin	Quản lý tài khoản quản trị, vai trò và cấu hình phân quyền ở mức hệ thống.

E.2. Cấu trúc Sơ đồ Use Case (Use Case Diagram)

E.2.1. Các Use Case bổ sung cho phạm vi mở rộng

Mã UC	Tên Use Case	Tác nhân	Mô tả
UC-16	Đăng ký gia nhập CLB	Hội viên/Sinh viên	Gửi đơn gia nhập và theo dõi trạng thái
UC-17	Duyệt đơn gia nhập CLB	Ban chủ nhiệm	Duyệt/từ chối, nhập lý do và ghi nhận người xử lý
UC-18	Quản lý Ban/Bộ phận	Admin/Super Admin	CRUD Ban/Bộ phận và trạng thái hoạt động
UC-19	Quản lý Chức vụ	Admin/Super Admin	CRUD chức vụ và quyền hạn
UC-20	Quản lý Nhiệm kỳ	Admin/Super Admin	Tạo nhiệm kỳ, phân công hội viên theo thời gian
UC-21	Xem Lịch hoạt động	Hội viên/Admin	Xem theo tháng/tuần, lọc theo loại hình
UC-22	Dashboard nâng cao	Admin	Biểu đồ hội viên, sự kiện, đăng ký, tham dự và Top hoạt động
UC-23	Tra cứu Audit Log	Admin/Super Admin	Tra cứu người thao tác, hành động, đối tượng và thời gian
UC-24	Kiểm tra chất lượng/Dependency	GitHub Actions	Chạy kiểm tra tự động trong CI
UC-25	Health Check & Smoke Test	GitHub Actions	Xác nhận staging hoạt động sau deploy

Sơ đồ Use Case tổng thể của hệ thống UniClub được chia làm 2 phân hệ chính, tương ứng với hai tác nhân con người:

HỆ THỐNG UNICLUB

[HỘI VIÊN]

├──── (UC-01: Đăng ký / Đăng nhập / Cập nhật hồ sơ)
├──── (UC-02: Tìm kiếm & Lọc sự kiện theo loại hình)
├──── (UC-03: Xem chi tiết sự kiện)
├──── (UC-04: Đăng ký tham gia sự kiện) ──<<include>>──> (UC-05: Điểm danh bằng mã QR)
├──── (UC-06: Theo dõi trạng thái & Lịch sử tham gia)
├──── (UC-07: Hủy đăng ký tham gia - khi sự kiện chưa diễn ra)
└──── (UC-08: Viết phản hồi & đánh giá sau sự kiện)

[BAN CHỦ NHIỆM CLB]

├──── (UC-09: Đăng nhập quản trị)
├──── (UC-10: Quản lý sự kiện - CRUD)
├──── (UC-11: Duyệt đơn gia nhập & Quản lý hội viên)
├──── (UC-12: Duyệt / Từ chối đăng ký tham gia) ──<<include>>──> (UC-13: Điểm danh thủ công)
├──── (UC-14: Đăng bài viết & Gửi thông báo)
└──── (UC-15: Xem Dashboard & Xuất báo cáo hoạt động)

E.3. Đặc tả chi tiết các Use Case chính

UC-01: Đăng ký tham gia sự kiện (Hội viên)

Mục	Nội dung
Mã Use Case	UC-01
Tên Use Case	Đăng ký tham gia sự kiện
Tác nhân	Hội viên (Sinh viên)
Tiền điều kiện	Hội viên đã đăng nhập vào hệ thống UniClub; sự kiện đang ở trạng thái mở đăng ký và còn ít nhất 1 chỗ trống.
Hậu điều kiện	Đăng ký tham gia được khởi tạo thành công ở trạng thái "Chờ duyệt"; số chỗ còn nhận đăng ký của sự kiện giảm tương ứng.

Luồng chính (Main Flow):

1. Hội viên truy cập trang chủ hoặc trang danh sách sự kiện của câu lạc bộ.
2. Hệ thống hiển thị danh sách sự kiện cùng hình ảnh, thời gian, địa điểm, loại hình và số chỗ còn nhận đăng ký.
3. Hội viên bấm vào sự kiện để xem chi tiết (nội dung chương trình, đối tượng tham gia, hướng dẫn tham dự).
4. Hội viên chọn hình thức tham gia (Trực tiếp/Trực tuyến) và nhấn "Đăng ký tham gia".
5. Hệ thống hiển thị biểu mẫu xác nhận thông tin hội viên (họ tên, lớp, số điện thoại liên hệ).
6. Hội viên kiểm tra lại thông tin và nhấn "Xác nhận đăng ký".
7. Hệ thống kiểm tra số chỗ còn lại trong cơ sở dữ liệu MySQL lần cuối, khởi tạo bản ghi đăng ký mới ở trạng thái "Chờ duyệt" và gửi thông báo thành công.
8. Hội viên có thể xem lại đăng ký vừa tạo trong mục "Lịch sử tham gia" với trạng thái "Chờ duyệt".

Luồng ngoại lệ (Exception Flows):

- Hết chỗ khi vừa xem chi tiết (Bước 4): Nếu sự kiện vừa hết chỗ trong lúc hội viên xem, hệ thống hiển thị thông báo "Sự kiện đã đủ số lượng đăng ký, vui lòng chọn hoạt động khác" và không cho đăng ký.
- Số chỗ không đủ khi xác nhận (Bước 7): Số chỗ còn lại trong database đã về 0 do người khác đăng ký trước. Hệ thống báo lỗi "Sự kiện đã đủ số lượng đăng ký, vui lòng chọn hoạt động khác!" và quay lại trang chi tiết sự kiện.
- Đăng ký trùng lặp (Bước 6): Hội viên đã đăng ký sự kiện này trước đó. Hệ thống báo "Bạn đã đăng ký tham gia sự kiện này rồi" và không tạo bản ghi mới.

UC-02: Điểm danh bằng mã QR (Hội viên)

Mục	Nội dung
Mã Use Case	UC-02
Tên Use Case	Điểm danh bằng mã QR khi tham dự sự kiện
Tác nhân	Hội viên
Tiền điều kiện	Hội viên có đăng ký tham gia đã được duyệt ("Đã duyệt") cho sự kiện đang diễn ra trong khung thời gian điểm danh. Mã QR là token động ngắn hạn, có thể đổi khoảng 20-30 giây/lần để giảm nguy cơ chia sẻ lại mã.
Hậu điều kiện	Trạng thái tham dự của hội viên chuyển thành "Đã điểm danh"; hệ thống lưu thời gian check-in và token đã xác thực để phục vụ thống kê/audit.

Luồng chính (Main Flow):

1. Tại sự kiện, Ban chủ nhiệm hiển thị mã QR điểm danh riêng cho sự kiện đó lên màn chiếu.
2. Hội viên mở ứng dụng/trang UniClub trên điện thoại, chọn chức năng "Điểm danh" và quét mã QR.
3. Hệ thống xác thực mã QR còn hiệu lực và khớp với sự kiện hội viên đã đăng ký.
4. Hệ thống kiểm tra hội viên có đăng ký ở trạng thái "Đã duyệt" cho sự kiện này hay không.

5. Nếu hợp lệ, hệ thống ghi nhận thời gian check-in và cập nhật trạng thái tham dự thành "Đã điểm danh" trong cơ sở dữ liệu MySQL.

6. Hệ thống hiển thị thông báo "Điểm danh thành công!" kèm tên sự kiện và thời gian check-in cho hội viên.

7. Ban chủ nhiệm có thể xem danh sách điểm danh cập nhật theo thời gian thực trên trang quản trị.

Luồng ngoại lệ (Exception Flows):

- Mã QR hết hạn hoặc sai sự kiện (Bước 3): Hệ thống báo lỗi "Mã điểm danh không hợp lệ hoặc đã hết hạn, vui lòng liên hệ Ban chủ nhiệm" và không ghi nhận điểm danh.

- Hội viên chưa được duyệt đăng ký (Bước 4): Hệ thống báo "Bạn chưa được duyệt tham gia sự kiện này, vui lòng liên hệ Ban chủ nhiệm" và giữ trạng thái không đổi.

- Điểm danh trùng lặp: Nếu hội viên đã điểm danh trước đó, hệ thống hiển thị "Bạn đã điểm danh cho sự kiện này rồi" và không ghi nhận thêm lần thứ hai.

UC-03: Duyệt đăng ký tham gia (Ban chủ nhiệm CLB)

Mục	Nội dung
Mã Use Case	UC-03
Tên Use Case	Duyệt đăng ký tham gia sự kiện
Tác nhân	Ban chủ nhiệm CLB
Tiền điều kiện	Ban chủ nhiệm đã đăng nhập vào hệ thống quản trị UniClub; có ít nhất một đăng ký mới ở trạng thái "Chờ duyệt".
Hậu điều kiện	Trạng thái đăng ký được chuyển thành "Đã duyệt" hoặc "Từ chối"; hội viên theo dõi được trạng thái mới khi xem lịch sử tham gia.

Luồng chính (Main Flow):

1. Ban chủ nhiệm truy cập vào mục "Quản lý đăng ký tham gia" trên trang quản trị.

2. Hệ thống hiển thị danh sách đăng ký được sắp xếp theo thời gian mới nhất (Mã đăng ký, Tên hội viên, Sự kiện, Ngày đăng ký, Trạng thái).

3. Ban chủ nhiệm nhấp vào dòng đăng ký để xem thông tin chi tiết hội viên và hình thức tham gia đã chọn.

4. Ban chủ nhiệm kiểm tra số chỗ còn lại của sự kiện.

5. Ban chủ nhiệm nhấn nút "Duyệt đăng ký".

6. Hệ thống cập nhật trạng thái đăng ký thành "Đã duyệt", đồng thời ghi nhận người xử lý và thời gian duyệt.

7. Hệ thống gửi thông báo cho hội viên biết đăng ký đã được duyệt và có thể điểm danh khi sự kiện diễn ra.

Luồng ngoại lệ (Exception Flows):

- Từ chối đăng ký (Bước 5): Khi sự kiện đã đủ số lượng hoặc hội viên không đủ điều kiện tham gia, Ban chủ nhiệm nhấn "Từ chối". Hệ thống yêu cầu nhập lý do (ví dụ: "Đã đủ số lượng đăng ký"). Hệ thống chuyển đăng ký sang trạng thái "Từ chối", hoàn trả lại chỗ trống cho sự kiện và gửi thông báo lý do cho hội viên.

UC-04: Quản lý sự kiện (Ban chủ nhiệm CLB)

Mục	Nội dung
Mã Use Case	UC-04
Tên Use Case	Quản lý sự kiện (CRUD)
Tác nhân	Ban chủ nhiệm CLB
Tiền điều kiện	Ban chủ nhiệm đã đăng nhập thành công vào trang quản trị UniClub với quyền phù hợp.
Hậu điều kiện	Thông tin sự kiện (tên, loại hình, thời gian, địa điểm, số chỗ tối đa, mô tả) được thêm/sửa/ẩn thành công trong CSDL MySQL và cập nhật ngay lập tức lên giao diện dành cho hội viên.

Luồng chính (Main Flow):

1. Ban chủ nhiệm truy cập vào menu "Quản lý sự kiện" trên thanh điều hướng quản trị.

2. Hệ thống hiển thị bảng danh sách tất cả sự kiện hiện có (có phân trang, ô tìm kiếm và lọc theo loại hình).

3. Thêm sự kiện mới: Ban chủ nhiệm nhấn "Thêm sự kiện mới"; hệ thống hiển thị biểu mẫu nhập liệu: Tên sự kiện, Loại hình (Học thuật/Tình nguyện/Giải trí...), Thời gian, Địa điểm, Số chỗ tối đa, Mô tả và hình ảnh minh họa.

4. Ban chủ nhiệm điền đầy đủ thông tin và nhấn "Lưu sự kiện". Hệ thống kiểm tra tính hợp lệ dữ liệu, lưu vào bảng SuKien trong MySQL và thông báo "Thêm sự kiện thành công!".

5. Cập nhật/Sửa sự kiện: Ban chủ nhiệm chọn một sự kiện từ danh sách, nhấn "Sửa"; hệ thống nạp thông tin hiện tại lên biểu mẫu để chỉnh sửa (ví dụ: điều chỉnh số chỗ tối đa hoặc thời gian).

6. Ẩn sự kiện: Ban chủ nhiệm chọn sự kiện và nhấn "Ẩn sự kiện"; hệ thống hiển thị hộp thoại xác nhận, sau đó cập nhật thuộc tính is_active = false (xóa mềm) để tránh phá vỡ dữ liệu lịch sử đăng ký/điểm danh.

Luồng ngoại lệ (Exception Flows):

- Dữ liệu nhập vào không hợp lệ (Bước 4, 5): Ban chủ nhiệm nhập Số chỗ tối đa là số âm hoặc để trống các trường bắt buộc (Tên, Thời gian, Địa điểm). Hệ thống chặn gửi biểu mẫu, hiển thị lỗi "Số chỗ tối đa phải là số nguyên dương lớn hơn 0" ngay tại trường vi phạm.

- Trùng tên sự kiện trong cùng khoảng thời gian (Bước 4): Hệ thống phát hiện đã tồn tại sự kiện cùng tên và cùng ngày diễn ra, báo lỗi "Sự kiện này đã tồn tại, vui lòng kiểm tra lại!".

E.4. Đặc tả Use Case mở rộng

QR điểm danh động: mỗi phiên điểm danh tạo token ngắn hạn và mã QR được làm mới định kỳ (khoảng 20-30 giây/lần). Server chỉ chấp nhận token còn hạn, đúng sự kiện và gắn với hội viên đã được duyệt. Cơ chế này giảm khả năng dùng lại ảnh chụp QR sau khi đã hết hạn.
UC-16 - Đăng ký gia nhập CLB: Hội viên đăng nhập, mở chức năng Gia nhập CLB, nhập thông tin cá nhân và lý do tham gia, gửi đơn. Hệ thống tạo bản ghi ở trạng thái Chờ duyệt, ghi ngày gửi và cho phép hội viên theo dõi lịch sử. Ban chủ nhiệm có thể duyệt hoặc từ chối kèm lý do; kết quả được lưu cùng người xử lý và thời gian xử lý.
UC-18/19/20 - Quản lý cơ cấu CLB: Admin tạo và quản lý Ban/Bộ phận, Chức vụ và Nhiệm kỳ; khi phân công một hội viên, hệ thống lưu Ban, Chức vụ, ngày bắt đầu và ngày kết thúc. Một hội viên có thể có nhiều lịch sử phân công theo các nhiệm kỳ khác nhau nhưng chỉ một phân công hiện hành trong cùng phạm vi.
UC-21 - Lịch hoạt động: Hệ thống hiển thị sự kiện theo tháng/tuần; màu hoặc nhãn thể hiện loại hoạt động. Người dùng có thể bấm vào một ngày để xem danh sách sự kiện, tình trạng đăng ký và số chỗ còn lại; Admin có thể lọc theo Ban phụ trách và loại hình.
UC-23 - Audit Log: Với thao tác nhạy cảm như tạo/sửa/ẩn sự kiện, duyệt thành viên, phân quyền hoặc thay đổi cơ cấu, hệ thống ghi lại người thực hiện, hành động, đối tượng, thời gian và thông tin truy cập phù hợp. Log chỉ cho phép vai trò được cấp quyền tra cứu.

F. THIẾT KẾ HỆ THỐNG VÀ THIẾT KẾ CHƯƠNG TRÌNH

F.1. Kiến trúc hệ thống

Dự án UniClub áp dụng mô hình kiến trúc 3 lớp (3-Tier Architecture) chuẩn cho ứng dụng Web Java Servlet/JSP, giúp phân tách rõ ràng giữa giao diện người dùng, xử lý nghiệp vụ và truy xuất cơ sở dữ liệu:

- Lớp Trình bày (Presentation Layer): các trang JSP + CSS/JS hiển thị danh sách sự kiện, biểu mẫu đăng ký, trang quản trị.

- Lớp Nghiệp vụ (Business/Service Layer): các Servlet và class Service xử lý logic đăng ký, điểm danh, duyệt đăng ký, tính tỷ lệ tham gia.

- Lớp Truy xuất dữ liệu (Data Access Layer - DAO): các class DAO thao tác trực tiếp với cơ sở dữ liệu MySQL thông qua JDBC.

- Toàn bộ mã nguồn được quản lý bằng Maven và đóng gói thành file WAR để triển khai lên Apache Tomcat, đồng thời là đơn vị build/test được GitHub Actions xử lý tự động trong pipeline CI/CD (xem mục F.5).

F.1.1. Lớp bảo mật và các yêu cầu xuyên suốt

Các yêu cầu xuyên suốt được áp dụng trên toàn hệ thống: xác thực Session, Authorization theo vai trò, kiểm tra dữ liệu đầu vào, truy vấn JDBC dạng PreparedStatement, mã hóa/mã băm mật khẩu, bảo vệ các URL quản trị, kiểm soát upload tệp, chống XSS/CSRF ở các biểu mẫu phù hợp và quản lý secret qua biến môi trường/GitHub Secrets.
Kiến trúc cũng bổ sung lớp Audit Logging cho các thao tác nhạy cảm và các endpoint Health Check/Smoke Test để pipeline CD có thể xác nhận bản triển khai hoạt động trước khi kết thúc workflow.

F.2. Class Diagram

Bản thiết kế hướng đối tượng (OOP) gồm 14 class cốt lõi và mở rộng làm nền tảng lập trình cho hệ thống UniClub.

Tên Class	Thuộc tính (Attributes)	Phương thức (Methods)	Vai trò & Trách nhiệm
NguoiDung	userId, hoTen, email, matKhau, sdt, lop, khoa, vaiTro	dangNhap(), dangKy(), doiMatKhau(), capNhatThongTin()	Lưu tài khoản dùng chung. vaiTro thống nhất theo 4 mức: MEMBER, DEPARTMENT_LEADER, ADMIN, SUPER_ADMIN; quyền thực tế được kiểm soát tại Filter/Authorization.
SuKien	eventId, tenSuKien, loaiHinh, moTa, thoiGian, diaDiem, soChoToiDa, soChoConLai, trangThai	getDanhSach(), themSuKien(), suaSuKien(), timKiem(), locTheoLoaiHinh()	Quản lý thông tin các sự kiện/hoạt động do câu lạc bộ tổ chức.
DangKyThamGia	registrationId, eventId, userId, hinhThucThamGia, ngayDangKy, trangThai	dangKy(), huyDangKy(), duyetDangKy(), tuChoiDangKy()	Quản lý đăng ký tham gia sự kiện và vòng đời trạng thái (Chờ duyệt → Đã duyệt → Đã điểm danh / Từ chối / Đã hủy).
DiemDanh	attendanceId, registrationId, thoiGianCheckIn, hinhThucDiemDanh	diemDanhQR(), diemDanhThuCong(), getTyLeThamGia()	Ghi nhận thời điểm hội viên có mặt tại sự kiện, phục vụ thống kê tỷ lệ tham gia.
BaiViet	postId, tieuDe, noiDung, userId, ngayDang, hinhAnh, trangThai	dangBaiViet(), suaBaiViet(), getDanhSachBaiViet()	Quản lý bài viết giới thiệu hoạt động câu lạc bộ hiển thị trên trang tin.
ThongBao	notificationId, tieuDe, noiDung, ngayGui, doiTuongNhan	guiThongBao(), getThongBaoTheoHoiVien()	Gửi thông báo đến toàn thể hội viên hoặc một nhóm hội viên cụ thể.
PhanHoi	feedbackId, eventId, userId, soSao, noiDung, ngayGui	guiPhanHoi(), getPhanHoiTheoSuKien()	Lưu phản hồi và chấm điểm (sao) của hội viên đối với sự kiện đã tham gia.
BanBoPhan	departmentId, tenBan, moTa, trangThai	themBan(), suaBan(), anBan()	Quản lý các Ban/Bộ phận trong CLB.
ChucVu	positionId, tenChucVu, moTa	themChucVu(), suaChucVu()	Quản lý chức vụ và vai trò tổ chức.
NhiemKy	termId, tenNhiemKy, ngayBatDau, ngayKetThuc, trangThai	taoNhiemKy(), capNhatNhiemKy()	Quản lý các nhiệm kỳ của CLB.
PhanCongThanhVien	assignmentId, userId, departmentId, positionId, termId, tuNgay, denNgay	phanCong(), ketThucPhanCong()	Liên kết hội viên với Ban, chức vụ và nhiệm kỳ theo thời gian.

Tên Class	Thuộc tính (Attributes)	Phương thức (Methods)	Vai trò & Trách nhiệm
DonGiaNhap	requestId, userId, lyDo, ngayGui, nguoiDuyet, ngayXuLy, lyDoTuChoi, trangThai	guiDon(), duyetDon(), tuChoiDon()	Quản lý vòng đời đơn gia nhập CLB.
AuditLog	logId, userId, action, objectType, objectId, timestamp, ipAddress	ghiLog(), traCuuLog()	Lưu vết các thao tác quản trị quan trọng.
QrToken	tokenId, eventId, token, expiresAt, createdAt	taoToken(), validateToken()	Quản lý QR động có thời hạn cho điểm danh.

F.3. Coding Convention thống nhất trong nhóm

Để đảm bảo chất lượng mã nguồn khi làm việc nhóm và để pipeline CI/CD có thể build/test ổn định, các thành viên tuân thủ các quy định sau:

- Quy tắc đặt tên: Class/Interface theo PascalCase (ví dụ: EventServlet, RegistrationDAO, UserService); biến/phương thức theo camelCase, tên rõ nghĩa (ví dụ: calculateAttendanceRate(), getEventById(), memberList); hằng số viết UPPERCASE_WITH_UNDERSCORE (ví dụ: MAX_RETRY_LOGIN = 3, DEFAULT_PAGE_SIZE = 10).

- Tên file JSP/HTML: viết thường, phân cách bằng dấu gạch ngang (ví dụ: event-detail.jsp, registration-list.jsp).

- Chuẩn Comment Code: bắt buộc viết Javadoc comment (/** ... */) cho tất cả Class, Interface và các hàm xử lý logic nghiệp vụ phức tạp (như tính tỷ lệ điểm danh, kiểm tra số chỗ còn lại, xác thực mã QR).

- Cấu trúc thư mục dự án theo chuẩn Maven: src/main/java chứa mã nguồn ứng dụng, src/test/java chứa toàn bộ Unit Test (JUnit) - đây là thư mục mà GitHub Actions sẽ chạy trong bước kiểm thử tự động.

- Cấu trúc package: com.uniclub.controller (Servlet tiếp nhận request), com.uniclub.dao (truy xuất CSDL MySQL), com.uniclub.model (đối tượng JavaBean/POJO), com.uniclub.service (xử lý logic nghiệp vụ), com.uniclub.filter (xác thực và phân quyền).

- Code Review: mọi Pull Request (PR) đẩy lên GitHub bắt buộc phải được ít nhất 01 thành viên khác kiểm tra và chấp thuận, đồng thời phải có trạng thái kiểm tra GitHub Actions CI ở mức PASS trước khi được phép gộp vào nhánh develop (Branch Protection Rule).

F.4. Quy tắc quản lý nhánh Git (Git Branching)

Tên nhánh	Mục đích sử dụng
main	Chứa mã nguồn ổn định nhất, dùng để nộp Bài tập lớn các đợt (Tuần 4, 7, 10) và Demo bảo vệ cuối kỳ. Mỗi lần có commit mới trên nhánh này, workflow CD tự động được kích hoạt để triển khai lên môi trường staging. Tuyệt đối không commit trực tiếp lên nhánh này.
develop	Nhánh tích hợp chính. Các chức năng hoàn thiện từ các nhánh feature được merge vào đây để kiểm thử tích hợp; mọi Pull Request vào nhánh này bắt buộc phải qua workflow CI (build + test) trước khi được duyệt.
feature/ten-chuc-nang	Nhánh riêng cho từng tính năng (ví dụ: feature/qr-checkin, feature/event-crud, feature/admin-dashboard). Thành viên phụ trách tự tạo từ nhánh develop; mỗi lần push đều kích hoạt workflow CI để phát hiện lỗi sớm.
hotfix/ten-loi	Nhánh xử lý khẩn cấp các lỗi phát sinh ngay trước buổi báo cáo hoặc demo, merge trực tiếp vào main sau khi CI pass để CD triển khai bản vá ngay lập tức.

Lịch sử Commit thực tế của nhóm (Sprint 1 & Sprint 2):

Nhánh	Người thực hiện	Nội dung Commit
feature/auth	Lưu Hữu Phát (Dev)	Khởi tạo trang DangKy, DangNhap và AuthFilter phân quyền

Nhánh	Người thực hiện	Nội dung Commit
feature/event-catalog	Lưu Hữu Phát (Dev)	Code EventDAO, hiển thị danh sách sự kiện theo loại hình
develop	Lưu Hữu Phát (Dev)	Merge feature/event-catalog vào develop sau khi CI PASS và BA Thơ review UI
feature/registration-checkin	Lưu Hữu Phát (Dev)	Xử lý đăng ký tham gia sự kiện và điểm danh bằng mã QR
feature/ci-pipeline	Lưu Hữu Phát (Dev)	Thêm workflow ci.yml: build Maven + chạy JUnit trên mọi Pull Request
develop	Lưu Hữu Phát (Dev)	Hoàn thiện chức năng Admin: Quản lý đăng ký và điểm danh thủ công
feature/cd-pipeline	Lưu Hữu Phát (Dev)	Thêm workflow cd.yml: tự động đóng gói WAR và triển khai lên Tomcat staging
main	Nguyễn Phương Linh (PM)	Merge develop vào main, chốt phiên bản nộp Bài tập lớn đợt 2, kích hoạt CD triển khai staging

F.5. Thiết kế chi tiết pipeline CI/CD bằng GitHub Actions

Đây là phần mở rộng trọng tâm của dự án: thay vì build và kiểm thử thủ công, nhóm thiết kế một pipeline tự động gồm hai workflow độc lập - CI (Continuous Integration) chạy trên mọi Pull Request/Push, và CD (Continuous Delivery) chạy khi mã nguồn được merge vào nhánh main. Pipeline được xây dựng vừa đủ để một nhóm sinh viên tự vận hành, không sử dụng hạ tầng phức tạp.

Mục tiêu của pipeline:

- Đảm bảo mọi thay đổi mã nguồn đều được build và kiểm thử tự động trước khi vào nhánh develop, giảm rủi ro lỗi hồi quy khi nhiều thành viên cùng code.
- Loại bỏ thao tác build & triển khai thủ công (copy file WAR, restart Tomcat bằng tay) - vốn dễ quên bước hoặc sai phiên bản.
- Cho phép Hội đồng giảng viên quan sát trực quan quy trình DevOps thực tế của nhóm ngay trong buổi Demo Day, thay vì chỉ nghe mô tả lý thuyết.

Công nghệ sử dụng trong pipeline (phù hợp công nghệ Java Servlet/JSP đang dùng):

Thành phần	Công nghệ / Công cụ	Vai trò
Build tool	Apache Maven 3.9	Biên dịch mã nguồn Java, quản lý thư viện (dependency), đóng gói thành file WAR
Ngôn ngữ & JDK	Java 17 (Temurin)	Môi trường chạy và biên dịch thống nhất giữa máy cá nhân và GitHub Actions runner
Unit Test	JUnit 5 + Mockito	Kiểm thử tự động các class Service/DAO trong bước CI
CI/CD Runner	GitHub Actions (ubuntu-latest) cho bước build/test; self-hosted runner cài trên máy nhóm cho bước deploy	Thực thi các bước của workflow theo cấu hình YAML
Máy chủ ứng dụng	Apache Tomcat 10 (môi trường staging nội bộ nhóm)	Nơi file WAR được triển khai tự động sau khi CD chạy thành công
Cơ sở dữ liệu	MySQL 8	Lưu trữ dữ liệu hội viên, sự kiện, đăng ký, điểm danh

Sơ đồ luồng pipeline (mô tả dạng văn bản):

1. Dev code trên nhánh feature/... → push lên GitHub.
2. GitHub tự động kích hoạt workflow ci.yml: checkout mã nguồn → cài JDK 17 → mvn -B test (build + chạy toàn bộ Unit Test).

3. Nếu CI FAIL: Pull Request bị Branch Protection Rule chặn, không cho phép merge; Dev phải sửa lỗi và push lại.

4. Nếu CI PASS: thành viên khác review code, duyệt Pull Request, merge vào nhánh develop.

5. Sau một thời gian kiểm thử tích hợp trên develop, PM tạo Pull Request merge develop vào main.

6. Khi merge vào main thành công, GitHub tự động kích hoạt workflow cd.yml: build lại → đóng gói file WAR → sao chép file WAR vào thư mục webapps của Apache Tomcat trên máy staging (thông qua self-hosted runner) → khởi động lại Tomcat.

7. Hệ thống UniClub trên môi trường staging được cập nhật tự động, sẵn sàng cho Demo Day mà không cần thao tác thủ công.

Ví dụ file cấu hình CI (.github/workflows/ci.yml):

```
name: CI - Build and Test
on:
  pull_request:
    branches: [ develop, main ]
  push:
    branches: [ develop ]
jobs:
  build-and-test:
    runs-on: ubuntu-latest
    steps:
      - uses: actions/checkout@v4
      - name: Set up JDK 17
        uses: actions/setup-java@v4
        with:
          java-version: '17'
          distribution: 'temurin'
          cache: maven
      - name: Build with Maven
        run: mvn -B compile
      - name: Run Unit Tests
        run: mvn -B test
      - name: Upload test report
        if: always()
        uses: actions/upload-artifact@v4
        with:
          name: surefire-reports
          path: target/surefire-reports
```

Ví dụ file cấu hình CD (.github/workflows/cd.yml):

```
name: CD - Package and Deploy Staging
on:
  push:
    branches: [ main ]
jobs:
  package-and-deploy:
    runs-on: self-hosted
    needs: []
    steps:
      - uses: actions/checkout@v4
      - name: Set up JDK 17
        uses: actions/setup-java@v4
        with:
          java-version: '17'
          distribution: 'temurin'
      - name: Build WAR package
        run: mvn -B clean package
      - name: Deploy to staging Tomcat
        run: |
          cp target/uniclub.war $TOMCAT_HOME/webapps/uniclub.war
          $TOMCAT_HOME/bin/shutdown.sh || true
          $TOMCAT_HOME/bin/startup.sh
```

Branch Protection Rule áp dụng cho nhánh develop và main:

- Bắt buộc trạng thái kiểm tra "CI - Build and Test" phải PASS trước khi cho phép merge Pull Request.

- Bắt buộc tối thiểu 1 lượt review được duyệt (Approve) từ thành viên khác trong nhóm.
- Không cho phép push trực tiếp (force push) hoặc xóa nhánh develop/main.

F.5.1. Pipeline CI/CD mở rộng: Code Quality, Security và Health Check

CI - Continuous Integration: checkout code → thiết lập JDK 17/Maven → compile/build → Unit Test (JUnit 5/Mockito) → kiểm tra code quality → kiểm tra dependency/security → upload báo cáo test → Branch Protection chỉ cho phép merge khi các check bắt buộc đạt.
CD - Continuous Delivery: merge vào main → build package WAR → triển khai lên Tomcat staging → kiểm tra Health Check endpoint → chạy Smoke Test các URL/chức năng cốt lõi → nếu kiểm tra thất bại thì đánh dấu deployment thất bại và thực hiện rollback bằng phiên bản ổn định đã biết.
Code Quality: nhóm có thể dùng Maven Checkstyle/SpotBugs hoặc công cụ tương đương để phát hiện lỗi phong cách và lỗi mã nguồn; nếu công cụ chưa được triển khai thực tế tại thời điểm nộp, tài liệu xem đây là bước thiết kế mở rộng và cần ghi rõ trạng thái trong Demo/Test Report.
Dependency Security Scan: kiểm tra thư viện Java và cảnh báo dependency có lỗ hổng; secret như mật khẩu CSDL, khóa hoặc token không được hard-code trong repository mà phải quản lý bằng GitHub Secrets hoặc biến môi trường trên runner.
Health Check và Smoke Test: sau khi Tomcat khởi động, pipeline gọi endpoint kiểm tra trạng thái ứng dụng và kiểm tra nhanh các luồng như trang đăng nhập, danh sách sự kiện và trang quản trị để xác nhận phiên bản mới đã chạy.

F.6. An toàn và bảo mật hệ thống

1. Mật khẩu: lưu dưới dạng giá trị băm an toàn, không lưu plaintext trong CSDL hoặc log.
2. SQL Injection: dùng PreparedStatement/parameterized query cho các thao tác JDBC.
3. Session & Authorization: kiểm tra Session và role tại Filter/Servlet; không cho phép truy cập trực tiếp các URL /admin/* khi không đủ quyền.
4. Input Validation: kiểm tra email, số điện thoại, số chỗ, ngày giờ, nội dung bài viết và tham số ID trước khi xử lý.
5. XSS/CSRF: encode dữ liệu khi hiển thị, không chèn trực tiếp HTML không tin cậy và áp dụng cơ chế chống CSRF cho các biểu mẫu thay đổi dữ liệu quan trọng.
6. Upload: giới hạn loại/ kích thước tệp, đổi tên tệp, không cho thực thi tệp tải lên và lưu ngoài vùng code thực thi khi có thể.
7. Secret Management: DB password, token, mật khẩu runner và thông tin triển khai được quản lý bằng biến môi trường/GitHub Secrets; không commit vào Git.
8. Audit Log: ghi lại hành động quản trị quan trọng và kiểm soát quyền tra cứu log.
9. Kiểm thử bảo mật: bổ sung test case cho truy cập trái phép, SQL Injection, XSS cơ bản, session/authorization và secret exposure.

F.7. Thiết kế cơ sở dữ liệu và ERD mở rộng

Mô hình dữ liệu được mở rộng để thể hiện rõ bản chất "quản lý câu lạc bộ", không chỉ quản lý sự kiện. Các quan hệ chính gồm: USERS → PHAN_CONG_THANH_VIEN → BAN_BO_PHAN/CHUC_VU/NHIEM_KY; USERS → DON_GIA_NHAP; USERS → DANG_KY_THAM_GIA → SU_KIEN → DIEM_DANH; USERS → BAI_VIET/PHAN_HOI/THONG_BAO; USERS → AUDIT_LOG; SU_KIEN → QR_TOKEN.

Bảng	Khóa chính	Khóa ngoại chính	Mục đích
Users	user_id	role_id (hoặc role)	Tài khoản và thông tin hội viên/quản trị.
BanBoPhan	department_id	-	Danh sách Ban/Bộ phận.
ChucVu	position_id	-	Danh mục chức vụ.
NhiemKy	term_id	-	Các nhiệm kỳ của CLB.
PhanCongThanhVien	assignment_id	user_id, department_id, position_id, term_id	Lịch sử phân công thành viên.
DonGiaNhap	request_id	user_id, nguoi_duyet	Đơn gia nhập và lịch sử xử lý.
SuKien	event_id	department_id (nếu phân công Ban phụ trách)	Thông tin hoạt động/sự kiện.
DangKyThamGia	registration_id	event_id, user_id	Đăng ký tham gia sự kiện.
DiemDanh	attendance_id	registration_id	Thông tin check-in.
AuditLog	log_id	user_id	Lưu vết hành động quản trị.

QrToken	token_id	event_id	Token QR động theo sự kiện và thời hạn.

G. TEST PLAN MỞ RỘNG (DỰ ÁN UNICLUB - 44 TEST CASE)

Kiểm thử được tổ chức theo từng nhóm chức năng trọng yếu của hệ thống, bao gồm cả nhóm kiểm thử dành riêng cho pipeline CI/CD. Mỗi chức năng bao gồm đầy đủ các kịch bản kiểm thử luồng chuẩn (Happy Path), trường hợp biên (Boundary Value), dữ liệu bất thường và bảo mật phân quyền.

G.1. Chức năng Đăng ký & Đăng nhập (Authentication)

Mã TC	Kịch bản & Dữ liệu đầu vào	Kết quả mong đợi (Expected Result)	Kết quả thực tế	Đánh giá
TC01	[Luồng chuẩn] Đăng nhập với email và mật khẩu chính xác (hoivien@gmail.com / Pass1234)	Đăng nhập thành công, lưu Session người dùng, hiển thị thông báo "Đăng nhập thành công" và chuyển hướng đến trang chủ.	Đang chờ	-
TC02	[Bất thường] Nhập đúng email nhưng sai mật khẩu 3 lần liên tiếp	Hệ thống từ chối đăng nhập, cảnh báo "Mật khẩu không chính xác. Bạn còn X lần thử trước khi tài khoản bị tạm khóa".	Đang chờ	-
TC03	[Biên/Rỗng] Bỏ trống ô Email hoặc Mật khẩu khi nhấn "Đăng nhập"	Hệ thống hiển thị lỗi "Vui lòng điền đầy đủ Email và Mật khẩu", ngăn gửi request.	Đang chờ	-
TC04	[Trùng lặp] Đăng ký tài khoản mới với email đã tồn tại trong CSDL	Hệ thống báo lỗi: "Email này đã được đăng ký, vui lòng dùng email khác hoặc chọn Quên mật khẩu".	Đang chờ	-
TC05	[Validation] Đăng ký với mật khẩu < 6 ký tự hoặc mật khẩu nhập lại không khớp	Báo lỗi validation tương ứng: "Mật khẩu phải chứa ít nhất 6 ký tự" hoặc "Mật khẩu xác nhận không khớp".	Đang chờ	-

G.2. Chức năng Tìm kiếm & Lọc sự kiện (Event Catalog)

Mã TC	Kịch bản & Dữ liệu đầu vào	Kết quả mong đợi (Expected Result)	Kết quả thực tế	Đánh giá
TC06	[Luồng chuẩn] Tìm kiếm sự kiện theo từ khóa tên sự kiện có kết quả	Hiển thị đúng danh sách sự kiện có tên khớp một phần hoặc toàn phần với từ khóa nhập vào.	Đang chờ	-
TC07	[Không có kết quả] Tìm kiếm với từ khóa không tồn tại trong hệ thống	Hiển thị thông báo "Không tìm thấy sự kiện phù hợp", không phát sinh lỗi hệ thống.	Đang chờ	-
TC08	[Lọc] Lọc sự kiện theo loại hình "Tình nguyện"	Danh sách chỉ hiển thị các sự kiện thuộc loại hình Tình nguyện, đúng số lượng trong CSDL.	Đang chờ	-
TC09	[Biên] Xem chi tiết sự kiện đã hết chỗ đăng ký (soChoConLai = 0)	Trang chi tiết hiển thị nhãn "Đã đủ số lượng đăng ký" và ẩn/khóa nút "Đăng ký tham gia".	Đang chờ	-

G.3. Chức năng Đăng ký tham gia & Điểm danh QR (Hội viên)

Mã TC	Kịch bản & Dữ liệu đầu vào	Kết quả mong đợi (Expected Result)	Kết quả thực tế	Đánh giá
TC10	[Luồng chuẩn] Hội viên đăng ký tham gia sự kiện còn chỗ trống	Đăng ký được tạo ở trạng thái "Chờ duyệt", số chỗ còn lại của sự kiện giảm 1.	Đang chờ	-
TC11	[Trùng lặp] Hội viên đăng ký lại sự kiện đã đăng ký trước đó	Hệ thống báo "Bạn đã đăng ký tham gia sự kiện này rồi", không tạo thêm bản ghi.	Đang chờ	-

Mã TC	Kịch bản & Dữ liệu đầu vào	Kết quả mong đợi (Expected Result)	Kết quả thực tế	Đánh giá
TC12	[Hết chỗ] Đăng ký khi số chỗ còn lại vừa về 0 do người khác đăng ký trước	Hệ thống báo "Sự kiện đã đủ số lượng đăng ký, vui lòng chọn hoạt động khác!".	Đang chờ	-
TC13	[Hủy đăng ký] Hội viên hủy đăng ký khi sự kiện chưa diễn ra	Đăng ký chuyển trạng thái "Đã hủy", số chỗ còn lại của sự kiện được cộng hoàn trả.	Đang chờ	-
TC14	[Điểm danh QR - chuẩn] Hội viên đã được duyệt quét đúng mã QR trong thời gian diễn ra sự kiện	Trạng thái tham dự chuyển "Đã điểm danh", ghi nhận đúng thời gian check-in.	Đang chờ	-
TC15	[Điểm danh QR - lỗi] Hội viên quét mã QR của sự kiện khác hoặc mã đã hết hạn	Hệ thống báo "Mã điểm danh không hợp lệ hoặc đã hết hạn", không ghi nhận điểm danh.	Đang chờ	-
TC16	[Điểm danh QR - chưa duyệt] Hội viên chưa được duyệt đăng ký cố quét mã QR	Hệ thống báo "Bạn chưa được duyệt tham gia sự kiện này", từ chối ghi nhận.	Đang chờ	-

G.4. Chức năng Quản lý sự kiện (Admin - CRUD)

Mã TC	Kịch bản & Dữ liệu đầu vào	Kết quả mong đợi (Expected Result)	Kết quả thực tế	Đánh giá
TC17	[Thêm mới] Ban chủ nhiệm thêm sự kiện mới với đầy đủ thông tin hợp lệ	Sự kiện mới xuất hiện ngay trên trang danh sách dành cho hội viên và trong CSDL uniclub_db.	Đang chờ	-
TC18	[Validation] Nhập Số chỗ tối đa là số âm hoặc để trống Tên sự kiện	Hệ thống chặn lưu, hiển thị lỗi đúng tại trường vi phạm, không ghi vào CSDL.	Đang chờ	-
TC19	[Ẩn sự kiện] Ban chủ nhiệm ẩn một sự kiện đã có hội viên đăng ký	Sự kiện không còn hiển thị cho hội viên mới nhưng lịch sử đăng ký/điểm danh cũ vẫn được giữ nguyên (xóa mềm).	Đang chờ	-

G.5. Chức năng Duyệt đăng ký & Điểm danh thủ công (Admin)

Mã TC	Kịch bản & Dữ liệu đầu vào	Kết quả mong đợi (Expected Result)	Kết quả thực tế	Đánh giá
TC20	[Duyệt] Ban chủ nhiệm duyệt một đăng ký ở trạng thái "Chờ duyệt"	Đăng ký chuyển trạng thái "Đã duyệt", hội viên nhận được thông báo.	Đang chờ	-
TC21	[Từ chối] Ban chủ nhiệm từ chối đăng ký kèm lý do "Đã đủ số lượng"	Đăng ký chuyển trạng thái "Từ chối", số chỗ còn lại của sự kiện được hoàn trả tự động.	Đang chờ	-
TC22	[Điểm danh thủ công] Ban chủ nhiệm xác nhận điểm danh thay cho hội viên không có điện thoại quét mã QR	Trạng thái tham dự của hội viên chuyển "Đã điểm danh", ghi rõ hình thức điểm danh là "Thủ công".	Đang chờ	-

G.6. Chức năng Bài viết, Thông báo, Dashboard & Phản hồi

Mã TC	Kịch bản & Dữ liệu đầu vào	Kết quả mong đợi (Expected Result)	Kết quả thực tế	Đánh giá
TC23	[Đăng bài viết] Ban chủ nhiệm đăng bài viết mới kèm hình ảnh	Bài viết hiển thị ngay trên trang tin của hội viên, đúng thứ tự thời gian đăng.	Đang chờ	-
TC24	[Gửi thông báo] Ban chủ nhiệm gửi thông báo đến toàn thể hội viên	Toàn bộ hội viên đang hoạt động nhận được thông báo trong mục thông báo cá nhân.	Đang chờ	-

Mã TC	Kịch bản & Dữ liệu đầu vào	Kết quả mong đợi (Expected Result)	Kết quả thực tế	Đánh giá
TC25	[Dashboard] Ban chủ nhiệm xem Dashboard sau khi có 1 sự kiện vừa kết thúc và đã điểm danh	Dashboard hiển thị đúng tổng số hội viên, tổng số sự kiện và tỷ lệ điểm danh trung bình được tính chính xác.	Đang chờ	-
TC26	[Dashboard - biên] Xem Dashboard khi chưa có sự kiện nào diễn ra	Hệ thống hiển thị tỷ lệ điểm danh = 0%, không phát sinh lỗi chia cho 0 (NullPointerException/ArithmeticException).	Đang chờ	-
TC27	[Phản hồi] Hội viên đã điểm danh gửi phản hồi 5 sao kèm nhận xét cho sự kiện	Phản hồi được lưu vào CSDL, điểm trung bình của sự kiện cập nhật ngay trên trang chi tiết.	Đang chờ	-
TC28	[Phản hồi - chặn] Hội viên chưa điểm danh cố gửi phản hồi cho sự kiện	Hệ thống từ chối, hiển thị "Bạn cần tham dự (điểm danh) sự kiện này để có thể gửi phản hồi".	Đang chờ	-

G.7. Kiểm thử pipeline CI/CD (GitHub Actions)

Mã TC	Kịch bản & Dữ liệu đầu vào	Kết quả mong đợi (Expected Result)	Kết quả thực tế	Đánh giá
TC29	[CI - chặn merge] Tạo Pull Request từ nhánh feature chứa 1 Unit Test cố tình thất bại	Workflow CI báo trạng thái FAIL; Branch Protection Rule chặn nút "Merge" trên GitHub cho đến khi lỗi được sửa.	Đang chờ	-
TC30	[CI - thành công] Push code hợp lệ lên nhánh feature, toàn bộ Unit Test đều pass	Workflow CI hiển thị trạng thái PASS (dấu tích xanh) trong tab Actions và trên Pull Request, cho phép merge.	Đang chờ	-
TC31	[CD - tự động triển khai] Merge Pull Request từ develop vào main	Workflow CD tự động chạy, đóng gói file WAR mới và triển khai lên Tomcat staging; truy cập lại địa chỉ staging thấy thay đổi mới nhất mà không cần thao tác thủ công.	Đang chờ	-
TC32	[CD - rollback thủ công] Bản merge vào main gây lỗi runtime trên staging	Nhóm revert commit lỗi trên GitHub, workflow CD tự động chạy lại và triển khai về đúng phiên bản ổn định trước đó.	Đang chờ	-

GHI CHÚ HƯỚNG DẪN: Các cột "Kết quả thực tế" và "Đánh giá" (Đạt/Không đạt) sẽ được nhóm thực hiện test trực tiếp trên môi trường Local/Tomcat Server và trên môi trường staging do pipeline CD triển khai, điền bổ sung hoàn chỉnh trong quá trình chạy kiểm thử Sprint 2-3 để làm Test Report chính thức cho đợt nộp Báo cáo Bài tập lớn cuối kỳ.

G.8. Test Case cho chức năng mở rộng, bảo mật và chất lượng CI/CD

Mã TC	Kịch bản & Dữ liệu đầu vào	Kết quả mong đợi (Expected Result)	Kết quả thực tế	Đánh giá
TC33	[Đăng ký gia nhập] Sinh viên gửi đơn gia nhập với dữ liệu hợp lệ	Tạo đơn ở trạng thái Chờ duyệt và cho phép theo dõi trạng thái.	Đang chờ	-
TC34	[Đăng ký gia nhập - thiếu dữ liệu] Bỏ trống lý do hoặc thông tin bắt buộc	Không cho gửi; hiển thị validation tại trường vi phạm.	Đang chờ	-
TC35	[Duyệt gia nhập] Admin duyệt đơn Chờ duyệt	Đơn chuyển Đã duyệt; tài khoản được ghi nhận là hội viên hoạt động; lưu người duyệt và thời gian.	Đang chờ	-
TC36	[Từ chối gia nhập] Admin từ chối đơn và nhập lý do	Đơn chuyển Từ chối; hội viên xem được lý do và lịch sử xử lý.	Đang chờ	-
TC37	[Cơ cấu CLB] Admin tạo Ban/Bộ phận và Chức vụ	Dữ liệu được lưu, hiển thị trong danh mục quản trị.	Đang chờ	-
TC38	[Nhiệm kỳ] Phân công hội viên vào Ban + Chức vụ trong một nhiệm kỳ	Bản ghi phân công lưu đúng thời gian; lịch sử cũ không bị mất.	Đang chờ	-

TC39	[Calendar] Xem lịch tháng/tuần và lọc theo loại sự kiện	Hiển thị đúng sự kiện theo khoảng thời gian và bộ lọc.	Đang chờ	-
TC40	[Dashboard nâng cao] Sau khi có dữ liệu mới, biểu đồ và KPI được cập nhật	Tổng hội viên, sự kiện, đăng ký, tỷ lệ tham dự và Top hoạt động tính đúng.	Đang chờ	-
TC41	[Audit Log] Admin thực hiện thay đổi sự kiện	Hệ thống tạo log gồm user, action, object, thời gian; người không có quyền không xem được log.	Đang chờ	-
TC42	[Authorization] Hội viên truy cập trực tiếp /admin/dashboard	Hệ thống từ chối truy cập và chuyển đến trang phù hợp/403.	Đang chờ	-
TC43	[Security] Nhập payload SQL Injection/XSS cơ bản vào biểu mẫu	Hệ thống không thực thi payload, dữ liệu được xử lý an toàn và không làm lộ/đổi dữ liệu ngoài ý muốn.	Đang chờ	-
TC44	[CI/CD mở rộng] Dependency/quality check hoặc smoke/health check thất bại	Pipeline đánh dấu FAIL và không coi deployment là thành công; nhóm có thể rollback về phiên bản ổn định.	Đang chờ	-

Ghi chú thống nhất tiến độ: 32 Test Case ban đầu được giữ nguyên; 12 Test Case mới được bổ sung, nâng tổng Test Plan lên 44 Test Case. Biên bản Sprint 2 ghi nhận đã thực thi 28 Test Case tại thời điểm họp; 4 Test Case còn lại của phạm vi ban đầu và 12 Test Case mở rộng được thực hiện/đánh giá trong Sprint 3 trước khi chốt Test Report cuối kỳ.

H. KỊCH BẢN BẢO VỆ (DEMO DAY) - ĐẦY ĐỦ 4 THÀNH VIÊN

Tổng thời gian trình bày và bảo vệ của nhóm là 12 phút, được phân chia cụ thể cho từng thành viên, bao gồm cả phần demo trực tiếp pipeline CI/CD:

Thời gian	**Nội dung trình bày**	**Người thực hiện**	**Thao tác trên Slide / Hệ thống Demo**
1.5 phút	Mở đầu & Tổng quan dự án: giới thiệu 4 thành viên và phân công vai trò; nêu vấn đề quản lý CLB thủ công và mục tiêu xây dựng UniClub kèm CI/CD.	PM (Nguyễn Phương Linh)	Trình chiếu Slide 1-4 (Project Charter, Bài toán quản lý, Kiến trúc 3 lớp).
3.0 phút	Demo Luồng Hội viên: đăng nhập, tìm kiếm sự kiện, lọc theo loại hình, đăng ký tham gia, quét mã QR điểm danh, xem lịch sử tham gia và gửi phản hồi.	Dev (Lưu Hữu Phát)	Thao tác trực tiếp trên giao diện Hội viên (http://localhost:8080/UniClub hoặc địa chỉ staging).
2.5 phút	Demo Luồng Ban chủ nhiệm: đăng nhập quản trị; xem Dashboard nâng cao; quản lý Ban/Bộ phận, Chức vụ và Nhiệm kỳ; duyệt đơn gia nhập; quản lý sự kiện; xem Calendar; duyệt đăng ký; điểm danh; đăng bài/thông báo; tra cứu Audit Log.	Dev (Nguyễn Ngọc Hoa hỗ trợ trình bày)	Chuyển sang giao diện quản trị (/admin/dashboard).
2.0 phút	Demo trực tiếp pipeline CI/CD: tạo một Pull Request nhỏ (ví dụ sửa văn bản thông báo), cho xem GitHub Actions tự động chạy CI; merge Pull Request vào main và cho xem workflow CD tự động triển khai, refresh trang staging để chứng minh thay đổi đã lên hệ thống mà không cần thao tác thủ công.	Dev kiêm DevOps (Lưu Hữu Phát)	Mở trực tiếp tab GitHub Actions và trang staging trên trình chiếu.
3.0 phút	Báo cáo kết quả kiểm thử: tổng quan 44 Test Case trên các nhóm chức năng và CI/CD; tỷ lệ đạt; các lỗi quan trọng; kiểm thử phân quyền/bảo mật và các lỗi đã phát hiện/khắc phục trong Sprint 2-3.	Tester (Đỗ Thị Thơ) và cả nhóm	Trình chiếu Slide Báo cáo Kiểm thử (bảng tổng hợp Test Results & biểu đồ Pass/Fail); mở sẵn IDE và MySQL Workbench.

Checklist chuẩn bị trước khi bước vào phòng bảo vệ

STT	Hạng mục kiểm tra	Chi tiết chuẩn bị	Trạng thái
1	Dữ liệu mẫu (Seed Data)	Chuẩn bị CSDL uniclub_db có sẵn 15 sự kiện mẫu và 03 tài khoản test (hoivien@gmail.com, banchunhiem@uniclub.vn, testuser@gmail.com).	HOÀN THÀNH
2	Môi trường Demo	Khởi động sẵn Apache Tomcat Server, MySQL Server trên máy chiếu; kiểm tra đường dẫn localhost:8080/UniClub và địa chỉ môi trường staging.	HOÀN THÀNH
3	Môi trường CI/CD	Mở sẵn tab GitHub Actions của repository, kiểm tra self-hosted runner cho bước CD đang ở trạng thái Online, chuẩn bị sẵn một nhánh nhỏ để demo Pull Request trực tiếp.	HOÀN THÀNH
4	Phương án dự phòng (Backup)	Quay sẵn 01 Video Demo full HD thời lượng 5 phút (bao gồm cả đoạn demo CI/CD) phòng trường hợp sự cố mạng hoặc Tomcat lỗi đột xuất.	HOÀN THÀNH
5	Slide & Tài liệu	Slide thuyết trình PDF/PPTX; in 03 bản Báo cáo Bài tập lớn đóng bìa kiếng gửi Hội đồng Giảng viên.	HOÀN THÀNH
6	Phân công phản biện	Linh nắm tổng quan nghiệp vụ; Phát giải trình CSDL, Servlet và pipeline CI/CD; Hoa giải trình JSP & Admin Module; Thơ giải trình Test Case và luồng xử lý lỗi.	HOÀN THÀNH

I. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

I.1. Kết luận

UniClub được mở rộng từ hệ thống tập trung vào đăng ký/điểm danh sự kiện thành hệ thống quản lý câu lạc bộ có cơ cấu tổ chức, nhiệm kỳ, quy trình gia nhập, lịch hoạt động, Dashboard và Audit Log. Thiết kế vẫn giữ kiến trúc 3 lớp Java Servlet/JSP, MySQL và quy trình GitHub Actions phù hợp với quy mô bài tập lớn.

I.2. Kết quả hướng tới

Hệ thống hướng tới ba giá trị chính: số hóa nghiệp vụ quản lý CLB; cung cấp dữ liệu thống kê phục vụ Ban chủ nhiệm; và chuẩn hóa quy trình phát triển phần mềm bằng CI/CD, kiểm thử tự động và kiểm soát chất lượng mã nguồn.

I.3. Hạn chế

Môi trường demo vẫn là staging nội bộ; một số bước quality/security scan có thể ở mức thiết kế nếu nhóm chưa tích hợp công cụ thực tế; việc gửi thông báo thời gian thực và các tích hợp bên ngoài chưa nằm trong MVP.

I.4. Hướng phát triển

Các phiên bản sau có thể bổ sung ứng dụng mobile/PWA, thông báo email hoặc push, tích hợp lịch cá nhân, quản lý ngân sách/thu chi, triển khai production có HTTPS, giám sát tập trung và mở rộng CI/CD theo nhiều môi trường dev-staging-production.

PHỤ LỤC - MẪU BIÊN BẢN HỌP NHÓM (MEETING MINUTES)

BIÊN BẢN HỌP NHÓM SỐ 08

- Dự án: Thiết kế và xây dựng UniClub - Hệ thống Quản lý Câu lạc bộ Sinh viên và Tự động hóa CI/CD
- Thời gian: 19h30 - 21h00, Ngày 10 tháng 04 năm 2026
- Địa điểm: Google Meet / Phòng tự học - Học viện Phụ nữ Việt Nam
- Chủ trì: Nguyễn Phương Linh (Project Manager)
- Thư ký: Đỗ Thị Thơ (BA / Tester)
- Thành viên tham dự: Nguyễn Phương Linh, Lưu Hữu Phát, Nguyễn Ngọc Hoa, Đỗ Thị Thơ (Đạt 100% sĩ số - 4/4).

1. Đánh giá công việc đã hoàn thành (Sprint 2)

- Lưu Hữu Phát (Lead Dev): hoàn thiện module Đăng ký tham gia, Điểm danh QR và Servlet xử lý duyệt đăng ký; triển khai workflow CD tự động deploy lên Tomcat staging; đã sửa lỗi workflow CI báo FAIL do sai phiên bản JDK giữa máy cá nhân và GitHub Actions runner.

- Nguyễn Ngọc Hoa (Dev): hoàn thiện giao diện Admin Dashboard, chức năng quản lý sự kiện, thêm mới sự kiện và upload hình ảnh minh họa.

- Đỗ Thị Thơ (Tester): thực thi 28 Test Case theo Test Plan tại thời điểm Sprint 2; 4 test case còn lại của phạm vi ban đầu tiếp tục được chạy ở Sprint 3; phát hiện 02 lỗi giao diện trên di động và 01 lỗi tính sai tỷ lệ điểm danh khi chưa có hội viên nào tham dự, đã báo Dev sửa xong.

- Nguyễn Phương Linh (PM): tổng hợp tài liệu Báo cáo BTL (Mục A đến Mục H); theo dõi tiến độ công việc và hoàn thiện Slide thuyết trình đợt cuối, bao gồm kịch bản demo CI/CD.

2. Khó khăn & Vấn đề tồn đọng

- Workflow CD ban đầu triển khai thất bại do self-hosted runner chưa được cấp quyền ghi vào thư mục webapps của Tomcat.

- Giải pháp: cấp quyền thư mục cho tài khoản chạy runner và thêm bước kiểm tra (health check) sau khi khởi động lại Tomcat trong workflow cd.yml.

3. Phân công công việc chuẩn bị cho Báo cáo / Bảo vệ (Demo Day)

Người phụ trách	Công việc được giao	Hạn hoàn thành	Ghi chú
Nguyễn Phương Linh	Thống nhất Slide thuyết trình; tổng duyệt kịch bản nói 12 phút; in 03 bản Báo cáo BTL đóng tập.	11/04/2026	Kiểm tra kỹ định dạng trang bìa
Lưu Hữu Phát	Chạy Script Seed Data cho CSDL MySQL; chuẩn bị môi trường Tomcat & self-hosted runner; quay 01 Video Demo backup luồng Hội viên và pipeline CI/CD.	11/04/2026	Test kịch bản demo trên máy chiếu
Đỗ Thị Thơ	Kiểm tra lại các chức năng Admin, xuất file báo cáo hoạt động; hỗ trợ kịch bản demo luồng Ban chủ nhiệm.	11/04/2026	Kiểm tra đường dẫn upload ảnh
Nguyễn Ngọc Hoa	Rà soát lần cuối bảng kết quả Test Report (cột Kết quả thực tế & Đánh giá); chuẩn bị câu hỏi Q&A phản biện.	11/04/2026	Cập nhật file Excel kết quả kiểm thử

Hồ sơ dự án được biên soạn dựa trên Đề cương chi tiết học phần DHIT20 (Theo QĐ 794/QĐ-HVPNVN, ngày 10/08/2023), Viện Công nghệ Thông tin - Học viện Phụ nữ Việt Nam.

PHỤ LỤC BỔ SUNG - YÊU CẦU HOÀN THIỆN ỨNG DỤNG, SINGLE ACTIVE ADMIN SESSION & RUNNABLE APPLICATION

Phần phụ lục này bổ sung nguyên vẹn nội dung yêu cầu triển khai được cung cấp kèm hồ sơ, được trình bày lại theo cấu trúc tiêu đề và đoạn văn để thuận tiện tra cứu. Toàn bộ nội dung hồ sơ dự án hiện có được giữ nguyên.

Hãy bổ sung tính năng "Single Active Session & Quản lý Phiên Admin Độc quyền" vào hệ thống UniClub (Java Servlet/JSP, MySQL, Apache Tomcat) với các yêu cầu nghiệp vụ và thiết kế kỹ thuật chi tiết sau:

1. YÊU CẦU NGHIỆP VỤ (BUSINESS REQUIREMENTS)

1. Duy nhất 1 máy giữ quyền Admin chính (Primary Active Session): - Tại một thời điểm, chỉ cho phép DUY NHẤT 1 thiết bị/máy tính đóng vai trò là Admin chính đang hoạt động trên tài khoản Admin.

2. Cơ chế Bổ nhiệm / Cấp phép máy mới: - Khi một máy/thiết bị khác đăng nhập vào tài khoản Admin, hệ thống KHÔNG được tự động ngắt kết nối máy cũ. - Yêu cầu đăng nhập của máy mới sẽ ở trạng thái "Chờ phê duyệt" (PENDING). - Máy Admin chính sẽ nhận được thông báo yêu cầu cấp quyền (gồm IP, Thiết bị/User-Agent, Thời gian). Máy mới chỉ được truy cập quyền Admin nếu được máy Admin chính chấp thuận/bổ nhiệm.

3. Quyền Cưỡng chế Đăng xuất (Kickout): - Máy Admin chính có màn hình "Quản lý phiên hoạt động" (Active Sessions Manager). - Admin chính có thể ngắt kết nối (Kick out) bất kỳ máy/phiên làm việc nào khác ra khỏi hệ thống bất kỳ lúc nào.

4. Nhật ký lưu vết không thể sửa/xóa (Immutable Audit Log): - Mọi hành động của từng máy (Đăng nhập, yêu cầu bổ nhiệm, duyệt/từ chối, kickout, thao tác quản trị) đều phải được lưu vết kèm thông tin: Máy nào làm (IP + Device User-Agent), Session ID, Thời gian, Hành động cụ thể. - CHỈ DUY NHẤT máy Admin chính mới có quyền truy cập xem trang Nhật ký lưu vết này. - Bắt buộc bảo vệ toàn vẹn lịch sử (Immutability): Dữ liệu log chỉ được phép GHI THÊM (INSERT) và ĐỌC (SELECT). Tuyệt đối KHÔNG viết API/hàm UPDATE hoặc DELETE cho bảng Nhật ký này dưới mọi hình thức.

2. THIẾT KẾ KỸ THUẬT & MÃ NGUỒN CẦN THỰC HIỆN

Hãy tạo/cập nhật mã nguồn chi tiết cho các thành phần sau:

1. Cơ sở dữ liệu (MySQL Script): - Bảng admin_sessions: session_id (PK), user_id, ip_address, device_info, is_primary (BOOLEAN), status ('PENDING', 'ACTIVE', 'KICKED', 'EXPIRED'), created_at, last_active. - Cập nhật bảng audit_logs: log_id (PK), user_id, session_id, ip_address, device_info, action, object_type, object_id, created_at.

2. Lớp Data Access Object (DAO): - AdminSessionDAO.java: Các hàm quản lý Session (tạo request, duyệt bổ nhiệm, kickout, kiểm tra trạng thái realtime). - AuditLogDAO.java: Thiết kế chuẩn Immutable — CHỈ chứa các hàm insertLog() và getLogs(), KHÔNG có hàm update hay delete.

3. Lớp Kiểm soát truy cập (Filter & Listener): - SingleActiveSessionFilter.java: Chặn mọi request truy cập đường dẫn /admin/*. Kiểm tra trạng thái session từ DB ở mỗi request. + Nếu status == KICKED, lập tức thực hiện session.invalidate(), xóa dữ liệu session và chuyển hướng về trang login kèm thông báo: "Phiên làm việc của bạn đã bị Admin chính ngắt kết nối". + Nếu không phải là Primary Admin, ngăn truy cập vào trang Nhật ký lưu vết (Audit Log).

4. Lớp Xử lý (Servlet) & Giao diện (JSP): - AdminSessionServlet.java: Tiếp nhận các thao tác: Duyệt bổ nhiệm máy mới, Từ chối, Kickout phiên. - admin-sessions.jsp: Giao diện dành riêng cho Admin chính để xem các thiết bị đang active, danh sách chờ duyệt bổ nhiệm và nút Kickout. - admin-audit-log.jsp: Giao diện hiển thị lịch sử lưu vết chi tiết theo IP/Thiết bị. Hãy viết trọn vẹn code cho các file SQL, Model, DAO, Filter, Servlet và JSP nêu trên, tuân thủ đúng Coding Convention Java Servlet/JSP của dự án UniClub.Hãy cập nhật và hoàn thiện tính năng "Single Active Session & Quản lý Thiết bị Admin" cho hệ thống UniClub (Java Servlet/JSP, Apache Tomcat, MySQL) với các cải tiến TỐI ƯU TRẢI NGHIỆM ĐĂNG NHẬP (tránh phải đăng nhập lại hoặc xin duyệt quá nhiều lần) như sau:

1. YÊU CẦU NGHIỆP VỤ NÂNG CẤP (BUSINESS REQUIREMENTS)

1. Tự động nhận diện "Thiết bị đã tin cậy" (Trusted Device): - Khi Admin chính phê duyệt/bổ nhiệm một máy mới, hệ thống tự động sinh ra một device_token (UUID/HMAC mã hóa) lưu vào Secure/HttpOnly Cookie trên máy đó (thời hạn 30 ngày). - Những lần đăng nhập tiếp theo trên CHÍNH THIẾT BỊ ĐÓ sẽ TỰ ĐỘNG ĐƯỢC CHẤP THUẬN, không bắt chờ duyệt lại ngoại trừ trường hợp bị Admin chính "Kickout" hoặc thu hồi quyền.

2. Duy trì phiên làm việc không bị ngắt quãng (Session Heartbeat & Remember Me): - Thêm cơ chế "Ghi nhớ đăng nhập" (Remember Me persistent token) để khi đóng/mở lại trình duyệt trên máy đã duyệt không phải gõ lại username/password. - Thêm đoạn script JavaScript Heartbeat ngầm gửi request nhẹ mỗi 5 phút khi tab trình duyệt đang mở để giữ HttpSession luôn sống, không bị Tomcat ngắt tự động sau 30 phút.

3. Vẫn đảm bảo tính năng Single Active Primary Session & Kickout: - Tại 1 thời điểm chỉ có 01 phiên làm việc đóng vai trò Admin chính (Primary Active). - Máy Admin chính có thể xem danh sách tất cả các "Thiết bị đã tin cậy" + "Phiên đang hoạt động" và có nút: + "Kickout ngay" (Ngắt kết nối tức thì phiên hiện tại). + "Thu hồi thiết bị" (Hủy Device Token để lần sau máy đó phải xin duyệt lại từ đầu).

4. Nhật ký lưu vết không thể sửa/xóa (Immutable Audit Log): - Lưu vết mọi sự kiện: Đăng nhập tự động qua Trusted Device, Xin duyệt máy mới, Phê duyệt, Kickout, Thu hồi thiết bị. - Thông tin lưu vết: Máy nào (IP + Device Info/User-Agent), Session ID, Device Token Hash, Thời gian, Hành động. - CHỈ Admin chính mới có quyền xem Audit Log. Tuyệt đối KHÔNG có hàm UPDATE hay DELETE dữ liệu log trong CSDL.

2. YÊU CẦU KĨ THUẬT & MÃ NGUỒN CẦN VIẾT

Hãy viết đầy đủ mã nguồn cho các thành phần sau:

1. Cơ sở dữ liệu (MySQL Script): - Bảng trusted_devices: device_id (PK), user_id, device_token_hash, device_info, ip_address, status ('APPROVED', 'REVOKED'), created_at, last_used_at, expires_at. - Bảng admin_sessions: session_id (PK), user_id, device_id, ip_address, device_info, is_primary, status ('ACTIVE', 'KICKED', 'EXPIRED'), created_at, last_active. - Bảng audit_logs: log_id (PK), user_id, ip_address, device_info, action, created_at.

2. Lớp Helper & DAO: - DeviceTokenUtil.java: Sinh token mã hóa, băm token (SHA-256) và xử lý Cookie bảo mật (HttpOnly, Secure, SameSite). - TrustedDeviceDAO.java: Kiểm tra token thiết bị, lưu thiết bị mới được duyệt, thu hồi thiết bị. - AdminSessionDAO.java & AuditLogDAO.java (chỉ INSERT & SELECT).

3. Lớp Filter & Servlet: - SingleActiveSessionFilter.java: + Kiểm tra trạng thái KICKED realtime. + Nhận diện Trusted Device Cookie để bỏ qua bước chờ duyệt. + Bảo vệ Audit Log chỉ cho Primary Admin xem. - AdminSessionServlet.java: Xử lý Duyệt máy, Kickout phiên, Thu hồi Trusted Device. - SessionHeartbeatServlet.java: Endpoint nhận request ping từ JavaScript để duy trì session.

4. Giao diện (JSP & JS): - heartbeat.js: Script chạy ẩn gửi AJAX ping duy trì session mỗi 5 phút. - admin-sessions.jsp: Giao diện danh sách phiên active + danh sách thiết bị đã tin cậy (có nút Kickout & Thu hồi thiết bị). - admin-audit-log.jsp: Trang tra cứu nhật ký thao tác. Hãy viết trọn vẹn mã nguồn cho các file trên, tuân thủ đúng kiến trúc Java Servlet/JSP của dự án UniClub.Bạn là một Chuyên gia Lập trình Full-Stack Java Web (Java Servlet/JSP, MySQL, JDBC, Maven, Bootstrap 5). Tôi gửi kèm hồ sơ dự án "UniClub - Hệ thống Quản lý Câu lạc bộ Sinh viên" (file đính kèm UniClub_HoSoDuAn.docx). Nhiệm vụ của bạn là dựa vào toàn bộ đặc tả yêu cầu, sơ đồ cơ sở dữ liệu và kiến trúc trong tài liệu để tạo cho tôi toàn bộ MÃ NGUỒN VÀ DỮ LIỆU CỦA MỘT ỨNG DỤNG HOÀN CHỈNH, CHẠY ĐƯỢC TẬN GỐC (RUNNABLE APPLICATION).

YÊU CẦU CỤ THỂ VỀ CÔNG NGHỆ VÀ CẤU TRÚC:

1. Công nghệ: - JDK 17, Java Servlet API 5.0/6.0 (Jakarta / javax compatible cho Tomcat 10). - JSP, JSTL, HTML5, Bootstrap 5, JavaScript (dùng cho QR code scanner/generator). - Thao tác CSDL: JDBC chuẩn, MySQL 8.0. - Quản lý dự án: Apache Maven (pom.xml).

2. Tài khoản Quản trị viên (Admin / Ban chủ nhiệm) bắt buộc khởi tạo sẵn trong CSDL: * Email: admin@uniclub.vn (hoặc Username: admin) * Mật khẩu: Admin@68nguyenchithanh * Vai trò (vaiTro): 1 (Ban chủ nhiệm CLB / Admin) * Trạng thái: Đã kích hoạt / Cho phép đăng nhập ngay lập tức.

3. Các Module chính cần sinh mã đầy đủ: * CSDL MySQL (schema.sql & data.sql chứa sẵn tài khoản Admin ở trên và dữ liệu mẫu 5 sự kiện). * Module Xác thực & Phân quyền: Đăng ký, Đăng nhập, Đăng xuất, AuthFilter chặn truy cập theo vai trò (Hội viên / Admin). * Module Quản lý Sự kiện (CRUD): Trang danh sách, xem chi tiết, lọc theo loại hình, tạo/sửa/ẩn sự kiện. * Module Đăng ký tham gia & Điểm danh: Đăng ký sự kiện, Điểm danh bằng mã QR (dùng thư viện JS QR), Duyệt/Từ chối đăng ký. * Module Quản trị & Dashboard: Thống kê số lượng hội viên, sự kiện, tỷ lệ điểm danh.

ĐỊNH DẠNG ĐẦU RA CẦN CUNG CẤP:

Hãy viết code ĐẦY ĐỦ, CHI TIẾT, KHÔNG DÙNG DẠNG RẮC RỐI HAY VIẾT TẮT (// TODO... hay // viết code ở đây...). Cung cấp toàn bộ các file theo cấu trúc dự án Maven chuẩn như sau:

1. pom.xml: Khai báo dependency (Servlet, JSP, JSTL, MySQL Connector, Jakarta/JavaEE).

2. schema.sql & data.sql: Tạo bảng (NguoiDung, SuKien, DangKyThamGia, DiemDanh, BaiViet, ThongBao, PhanHoi) và thêm sẵn dữ liệu Admin Admin@68nguyenchithanh cùng dữ liệu test.

3. Classes Model (POJO): NguoiDung.java, SuKien.java, DangKyThamGia.java, DiemDanh.java, v.v.

4. Class DBContext / DatabaseConnection: Kết nối JDBC tới MySQL.

5. Classes DAO: NguoiDungDAO.java, SuKienDAO.java, DangKyDAO.java, DiemDanhDAO.java (đầy đủ các hàm CRUD và SQL Query).

6. Classes Filter: AuthFilter.java (kiểm tra Session, phân quyền Admin/Hội viên).

7. Classes Servlet (Controller): * LoginServlet.java, RegisterServlet.java, LogoutServlet.java * EventServlet.java (Danh sách, Tìm kiếm, Chi tiết) * EventManageServlet.java (Admin CRUD sự kiện) * RegistrationServlet.java (Đăng ký, Duyệt/Từ chối) * CheckinServlet.java (Điểm danh QR) * AdminDashboardServlet.java (Dashboard & Thống kê)

8. Các trang Giao diện JSP (Views - tích hợp Bootstrap 5): * login.jsp, register.jsp * index.jsp (Trang chủ & Danh sách sự kiện) * event-detail.jsp (Chi tiết & Đăng ký) * qr-checkin.jsp (Điểm danh QR) * admin/dashboard.jsp, admin/event-list.jsp, admin/event-form.jsp, admin/registration-list.jsp Hãy bắt đầu bằng việc hiển thị cấu trúc cây thư mục dự án, file pom.xml, file SQL (schema.sql và data.sql), sau đó viết code chi tiết cho từng file Java Servlet/DAO và trang JSP. thêm nội dung nay f vào word một cahs hợp lý và giữ nguyê nội dung cũ ttrong word và xuất file cho tôi

--- Hết nội dung bổ sung ---

PHỤ LỤC CHUYÊN GIA

RÀ SOÁT KHOẢNG TRỐNG VÀ BỔ SUNG TIÊU CHUẨN HOÀN THIỆN ỨNG DỤNG UNICLUB

Ngày rà soát: 24/10/2026 | Phạm vi: hồ sơ Word và đặc tả được cung cấp

Mục đích phụ lục: bổ sung trực tiếp các yêu cầu và tiêu chí còn thiếu để nhóm có thể dùng làm checklist hoàn thiện UniClub, đồng thời giữ nguyên toàn bộ nội dung đã có trong hồ sơ trước phụ lục này. Đây là rà soát trên tài liệu thiết kế/yêu cầu; chưa phải xác nhận rằng mã nguồn hoặc website đang chạy đã đáp ứng các yêu cầu dưới đây.

Cách đọc: P0 = cần chốt trước khi tiếp tục code hoặc trước khi bảo vệ; P1 = nên hoàn thành trong MVP nếu chức năng liên quan được đưa vào phạm vi; P2 = có thể đưa vào phiên bản sau. Các phần ghi "đề xuất" là bổ sung thiết kế, không phải kết quả triển khai đã được xác minh.

J.1. Nhận xét tổng quan của chuyên gia

Hồ sơ hiện tại có nền tảng tốt: mục tiêu và phạm vi dự án tương đối rõ; backlog có 39 User Story; mô tả được kiến trúc Servlet/JSP - Service - DAO; có đặc tả use case, bảng rủi ro, 44 test case, quy trình CI/CD, kịch bản Demo Day và yêu cầu quản lý phiên Admin độc quyền. Phần cần nâng cấp không phải là thêm nhiều chức năng ngẫu nhiên, mà là khóa các quy tắc nghiệp vụ và thống nhất cách triển khai để tránh lỗi dữ liệu, lỗi phân quyền và sai lệch giữa tài liệu với code.

Ưu tiên cao nhất là: (1) chuẩn hóa vai trò và quyền của phiên Admin chính; (2) thiết kế an toàn cho Trusted Device/Remember Me/Kickout; (3) đảm bảo đăng ký sự kiện không vượt số chỗ khi có nhiều người thao tác đồng thời; (4) thống nhất ID Use Case, bảng CSDL, phiên bản Tomcat/Servlet và đường dẫn triển khai; (5) bổ sung kiểm thử cho các luồng mới và chỉ ghi kết quả test sau khi thực thi thật.

J.2. Những điểm chưa nhất quán cần xử lý

Mức / Hạng mục	Điểm phát hiện trong hồ sơ	Bổ sung / quyết định đề xuất
P0 - ID Use Case	Sơ đồ văn bản dùng UC-01 cho đăng ký/đăng nhập, UC-02 cho tìm kiếm sự kiện; phần đặc tả E.3 lại dùng UC-01 cho đăng ký sự kiện, UC-02 cho QR, UC-03 cho duyệt đăng ký, UC-04 cho CRUD sự kiện.	Lập một danh mục UC duy nhất; mỗi mã chỉ gắn với một tên và một luồng. Cập nhật sơ đồ, bảng mô tả, test case và demo theo cùng mã.
P0 - Vai trò nhóm	Trang đầu ghi Nguyễn Ngọc Hoa là Tester và Đỗ Thị Thơ là BA; biên bản họp lại ghi Hoa làm Dev, Thơ làm Tester; phần demo cũng giao Tester cho Thơ.	Chốt một bảng phân công/RACI chính thức theo công việc thực tế. Giữ nguyên biên bản đã xảy ra nhưng ghi rõ nếu vai trò thay đổi theo sprint; đồng bộ trang đầu, WBS, test plan và kịch bản bảo vệ.
P0 - Sprint và mốc tuần	Tài liệu nói 3 sprint gắn với tuần 4, 7, 10 nhưng đồng thời có Sprint 0 tuần 1-4, Sprint 1 tuần 5, Sprint 2 tuần 6-7 và Sprint 3 tuần 8-10.	Phân biệt Sprint 0 (khởi động/đặc tả) với các sprint phát triển, hoặc sửa lịch để đúng 3 mốc môn học. Tên sprint, phạm vi tuần và sản phẩm bàn giao phải khớp ở Project Charter, WBS và Demo Day.
P0 - Ưu tiên chức năng	QR tự điểm danh được mô tả trong MVP nhưng US18 được xếp "Nên có"; một số chức năng được gọi là MVP nhưng ở sprint/ưu tiên khác nhau.	Lập bảng "MVP bắt buộc" cuối cùng. Nếu QR là cam kết MVP thì đổi mức ưu tiên tương ứng và có test pass trước khi chốt phiên bản; nếu không, ghi rõ phần nào là demo mở rộng.
P0 - Quyền Admin	Tài liệu có MEMBER, DEPARTMENT_LEADER, ADMIN, SUPER_ADMIN; phần phụ lục thêm "Primary Admin session". Primary Admin có lúc được mô tả như vai trò, có lúc là trạng thái phiên.	Giữ role là quyền nghiệp vụ; "Primary Admin" là quyền kiểm soát gắn với một phiên đang hoạt động. Chỉ một phiên toàn hệ thống được giữ quyền Primary tại một thời điểm; chỉ phiên này được quản lý phiên và xem Audit Log theo yêu cầu hiện tại.
P0 - Tin cậy và đăng nhập	Trusted Device được mô tả vừa là tự động bỏ qua bước duyệt, vừa có Remember Me tự đăng nhập; hai chức năng này dễ bị nhập làm một và làm yếu xác thực.	Tách riêng token thiết bị tin cậy và token Remember Me. Trusted Device chỉ bỏ qua phê duyệt thiết bị sau khi đã xác thực người dùng; Remember Me là thông tin xác thực dài hạn riêng, có hash, hạn dùng, xoay vòng và thu hồi.
P0 - CSDL và tên bảng	Sơ đồ dùng USERS, phần Class Diagram dùng NguoiDung/SuKien, phụ lục yêu cầu NguoiDung/SuKien nhưng thêm audit_logs/admin_sessions/trusted_devices; quy ước tên cột cũng chưa đồng nhất.	Chọn một bộ tên bảng/cột làm nguồn sự thật trước khi viết DAO và schema.sql. Dùng mapping ở mục J.5 để giữ tên class Java hiện có nhưng không dùng nhiều tên khác nhau cho cùng một bảng.
P0 - Servlet API	Tài liệu chọn Java 17 và Tomcat 10 nhưng chưa khóa phiên bản Jakarta Servlet và namespace import.	Nếu giữ Tomcat 10.1 thì dùng jakarta.servlet.* và Jakarta Servlet 6.0; không dùng lẫn javax.servlet.*. Nếu code hiện tại phụ thuộc javax thì phải chuyển mã hoặc chọn Tomcat 9 và cập nhật tài liệu/CI.

Mức / Hạng mục	Điểm phát hiện trong hồ sơ	Bổ sung / quyết định đề xuất
P0 - URL/Artifact deploy	Ví dụ CD chép uniclub.war (context mặc định /uniclub) nhưng kịch bản demo ghi /UniClub. Trên Linux, chữ hoa/chữ thường có thể khác nhau.	Thống nhất tên file WAR và URL. Khuyến nghị dùng uniclub.war + /uniclub xuyên suốt README, health check, smoke test, tài liệu và video demo.
P0 - Test report	Test plan đánh dấu phần lớn test case "Đang chờ", còn biên bản nói đã thực thi 28 test case; phần kịch bản bảo vệ dự kiến trình bày tỷ lệ đạt.	Không điền tỷ lệ đạt theo dự kiến. Tester cần ghi ngày chạy, môi trường, kết quả thực tế, bằng chứng và bug ID; số test đã chạy trong biên bản phải khớp bảng Test Report.
P0/P1 - Sơ đồ và giao diện	Mục Use Case hiện có sơ đồ dạng văn bản; Class Diagram chủ yếu là bảng liệt kê class; ERD được mô tả quan hệ và bảng khóa, chưa thể hiện đầy đủ sơ đồ trực quan có cardinality/PK/FK. Chưa có wireframe/ảnh chụp các luồng giao diện cốt lõi trong phần thiết kế.	Xuất sơ đồ Use Case, ERD và Class Diagram từ StarUML; thể hiện PK/FK, bội số quan hệ và các actor. Bổ sung sơ đồ kiến trúc triển khai và wireframe/ảnh giao diện cho đăng nhập, danh sách/chi tiết sự kiện, đăng ký, Admin Dashboard và quản lý phiên. Nếu hồ sơ dài, thêm mục lục tự động và danh mục hình/bảng.
P1 - Quan hệ Use Case	Đăng ký tham gia sự kiện được nối <<include>> với điểm danh QR; duyệt/từ chối đăng ký được nối <<include>> với điểm danh thủ công. Đây không phải quan hệ bắt buộc mọi lần.	Tách Đăng ký, Duyệt đăng ký và Điểm danh thành use case độc lập; thể hiện quan hệ điều kiện/tuỳ chọn khi phù hợp. Đăng ký không đồng nghĩa với điểm danh.
P1 - Thông báo thời gian thực	US21 mô tả danh sách đăng ký theo "thời gian thực" nhưng chưa quy định công nghệ cập nhật hay độ trễ chấp nhận được.	Nếu không dùng WebSocket/SSE, mô tả rõ cập nhật bằng polling/làm mới. Đặt tiêu chí kiểm thử, ví dụ dữ liệu mới xuất hiện trong vòng 30-60 giây ở môi trường demo.
P1 - Đếm chỗ	Tài liệu nói số chỗ giảm khi tạo đơn chờ duyệt và tăng lại khi từ chối/hủy, nhưng chưa chốt cách xử lý nhiều người đăng ký cùng lúc và cập nhật trùng.	Dùng transaction + khóa hàng hoặc câu lệnh cập nhật có điều kiện; đặt unique constraint cho cặp (event_id, user_id). Chỉ cập nhật số chỗ một lần theo chuyển trạng thái hợp lệ.
P1 - Báo cáo	Dashboard có tỷ lệ điểm danh nhưng chưa định nghĩa rõ mẫu số, cách xử lý sự kiện chưa diễn ra hoặc không có người được duyệt.	Dùng công thức chuẩn ở mục J.6; trường hợp mẫu số bằng 0 phải trả 0% và không gây lỗi chia cho 0.
P1 - Mật khẩu khởi tạo	Phụ lục triển khai có nêu dữ liệu tài khoản Admin mẫu; chưa mô tả chặt việc sinh và đổi mật khẩu khởi tạo.	Không hard-code mật khẩu thật trong source, SQL seed hoặc Git. Tạo hash an toàn, lấy mật khẩu qua biến môi trường/thiết lập local, bắt buộc đổi sau lần đăng nhập đầu và không ghi mật khẩu/token vào log.

J.3. Quyết định kỹ thuật nên chốt trước khi code tiếp

Các lựa chọn sau giúp tránh việc mỗi Servlet/DAO hoặc mỗi thành viên dùng một giả định khác nhau:

- Nền tảng: Java 17 + Maven + Tomcat 10.1 + Jakarta Servlet 6.0 + JSP 3.1 + MySQL 8; tất cả import Servlet phải dùng jakarta.servlet.*. Dependency Servlet API đặt scope provided.
- Kiến trúc: JSP chỉ trình bày; Servlet nhận request/điều hướng; Service xử lý quy tắc nghiệp vụ và transaction; DAO dùng PreparedStatement để truy xuất MySQL; Filter kiểm tra xác thực/phân quyền; tiện ích bảo mật đặt ở package riêng.
- Cấu trúc package đề xuất: com.uniclub.controller, com.uniclub.service, com.uniclub.dao, com.uniclub.model, com.uniclub.filter, com.uniclub.util, com.uniclub.config.
- Tên URL và context path: chuẩn hóa một dạng chữ thường, ví dụ /uniclub/login, /uniclub/events, /uniclub/admin/dashboard. Không ghi rải rác cả /UniClub và /uniclub.
- Cấu hình: không để mật khẩu DB, secret token hoặc thông tin tài khoản thật trong Java/SQL/README. Cung cấp db.properties.example hoặc biến môi trường, còn file cấu hình thật nằm ngoài Git và được thêm vào .gitignore.
- Các trạng thái tài khoản, đơn gia nhập, đăng ký sự kiện, phiên Admin và thiết bị tin cậy phải dùng enum/hằng số thống nhất; tránh so sánh bằng chuỗi tự do ở nhiều Servlet.

J.4. Ma trận quyền truy cập cần bổ sung

Quyền phải được kiểm tra ở Filter/Service/DAO phía máy chủ; ẩn nút trên giao diện không được coi là biện pháp phân quyền. "Primary Admin" là đặc tính của một phiên được cấp quyền, không thay thế role của tài khoản.

Vai trò/phiên	Được phép	Giới hạn bắt buộc
Khách chưa đăng nhập	Xem trang công khai và danh sách sự kiện công khai; gửi yêu cầu đăng ký tài khoản.	Không xem hồ sơ hội viên, lịch sử, chức năng Admin hoặc dữ liệu nội bộ.
Hội viên MEMBER	Cập nhật hồ sơ; gửi/theo dõi đơn gia nhập; đăng ký/hủy sự kiện theo quy tắc; xem lịch sử của chính mình; điểm danh và phản hồi khi đủ điều kiện.	Không đọc/sửa dữ liệu của hội viên khác; không tự duyệt đơn hoặc tự đánh dấu đã điểm danh.
Trưởng ban DEPARTMENT_LEADER	Quản lý hoạt động/thành viên trong phạm vi Ban được phân công; xem thống kê phạm vi Ban nếu được bật.	Mọi truy vấn phải giới hạn department_id được cấp; không thay đổi quyền hệ thống hoặc xem log độc quyền.

Vai trò/phiên	Được phép	Giới hạn bắt buộc
Admin đã được xác thực nhưng không phải Primary	Thực hiện tác vụ quản trị CLB theo role ADMIN nếu chính sách dự án cho phép.	Không được duyệt/thu hồi thiết bị, kickout phiên hoặc xem Audit Log độc quyền của Primary Admin.
Primary Admin session	Thực hiện quyền ADMIN được cấp; quản lý phiên, duyệt thiết bị mới, kickout, thu hồi thiết bị và xem Audit Log.	Không được có hai phiên Primary đồng thời; thao tác nhạy cảm cần POST + CSRF token và ghi log.
SUPER_ADMIN	Quản lý tài khoản quản trị, role và cấu hình ở mức hệ thống theo phân quyền được phê duyệt.	Theo yêu cầu phụ lục hiện tại, quyền SUPER_ADMIN không tự động vượt qua điều kiện "chỉ Primary Admin xem Audit Log"; nếu cần ngoại lệ phải sửa đặc tả và ghi audit.

J.5. Quy ước mô hình dữ liệu và ràng buộc

Đề xuất giữ tên class Java tiếng Việt đang có trong Class Diagram, nhưng dùng tên bảng SQL lowercase_snake_case nhất quán để giảm lỗi do cách viết hoa/thường. Nếu nhóm đã có schema chạy thật, cần chọn schema đó làm nguồn sự thật và cập nhật mapping trước khi tiếp tục code; không tạo song song hai bảng cho cùng một nghiệp vụ.

Class/nghiệp vụ	Tên bảng SQL đề xuất	Ràng buộc/ghi chú
NguoiDung	users	email UNIQUE; password_hash; role/status; created_at/updated_at.
SuKien	events	capacity > 0; start_time < end_time; is_active; department_id nếu có Ban phụ trách.
DangKyThamGia	event_registrations	FK users/events; UNIQUE(event_id, user_id); status; reviewed_by/reviewed_at/rejection_reason.
DiemDanh	attendance	FK event_registrations; UNIQUE(registration_id); checked_in_at; method = QR/MANUAL.
BaiViet	posts	author_id FK users; status; created_at/published_at; kiểm soát file ảnh.
ThongBao	notifications + notification_recipients	Tách nội dung thông báo khỏi từng người nhận để lưu read_at và trạng thái đã đọc.
PhanHoi	feedback	FK event/user; UNIQUE(event_id, user_id) nếu mỗi hội viên chỉ đánh giá một lần; chỉ cho gửi khi đã điểm danh.
BanBoPhan / ChucVu / NhiemKy	departments / positions / terms	Có is_active/status; ngày kết thúc không nhỏ hơn ngày bắt đầu.
PhanCongThanhVien	member_assignments	FK user/department/position/term; từ ngày/đến ngày; truy vấn lịch sử không ghi đè nhiệm kỳ cũ.
DonGiaNhap	membership_requests	FK user; status; reviewer/reviewed_at/rejection_reason; cần quy tắc một đơn đang chờ cho mỗi user.
QrToken	qr_tokens	FK event; token hash hoặc nonce; expires_at; không ghi token thô vào log.
AuditLog	audit_logs	Append-only; actor/session/device/action/object/timestamp; không có chức năng sửa/xóa qua ứng dụng.
Phiên Admin	admin_sessions	Mỗi bản ghi đại diện phiên ứng dụng; internal session UUID; status và last_active; không lưu raw HttpSession ID như bearer secret.
Thiết bị tin cậy	trusted_devices	device_token_hash; APPROVED/REVOKED; expires_at; last_used_at; thu hồi phải có hiệu lực với những phiên gắn thiết bị đó.
Remember Me	remember_tokens	Token ngẫu nhiên riêng, chỉ lưu hash; expires_at, last_used_at, revoked_at; có rotation và chống replay.
Điều khiển Primary	admin_control	Một bản ghi khóa/điểm neo toàn cục hoặc cơ chế DB tương đương để bảo đảm chỉ một Primary tại một thời điểm.

Ràng buộc dữ liệu tối thiểu cần có: khóa ngoại cho quan hệ chính; UNIQUE cho email và cặp sự kiện-hội viên; CHECK hoặc validate server cho capacity/số sao/ngày giờ; chỉ mục cho event start_time, registration status, user_id, audit created_at và session status. Mọi thao tác thay đổi đồng thời (đặt chỗ, duyệt đăng ký, cấp Primary, kickout, thu hồi thiết bị) phải được thực hiện trong transaction phù hợp.

J.6. Quy tắc nghiệp vụ cốt lõi để tránh lỗi khi chạy thật

J.6.1. Đăng ký sự kiện và chống vượt số chỗ

- Định nghĩa trước trạng thái chiếm chỗ: khuyến nghị PENDING và APPROVED cùng chiếm chỗ; REJECTED, CANCELLED và EXPIRED không chiếm chỗ. Khi đăng ký tạo PENDING, giữ chỗ đúng một lần; khi từ chối/hủy/đơn hết hiệu lực, trả chỗ đúng một lần.
- Trong một transaction: kiểm tra sự kiện còn mở; kiểm tra user chưa có đăng ký active cho event; khóa hàng sự kiện hoặc dùng UPDATE có điều kiện capacity_remaining > 0; tạo đăng ký; commit. Nếu bất kỳ bước nào lỗi thì rollback.
- Không tin số chỗ từ trình duyệt. CSDL phải có UNIQUE(event_id, user_id) hoặc cơ chế tương đương để chặn hai request song song tạo đăng ký trùng. Không trừ số chỗ ở cả lúc gửi đơn lẫn lúc Admin duyệt.

J.6.2. Quy tắc trạng thái đơn gia nhập và đăng ký sự kiện

Đối tượng	Trạng thái chuẩn đề xuất	Quy tắc chuyển trạng thái
Đơn gia nhập CLB	PENDING, APPROVED, REJECTED, WITHDRAWN	PENDING → APPROVED/REJECTED; chỉ người có quyền duyệt mới chuyển; từ chối cần lý do; lưu người xử lý và thời gian.
Đăng ký sự kiện	PENDING, APPROVED, REJECTED, CANCELLED, CHECKED_IN	PENDING → APPROVED/REJECTED/CANCELLED; APPROVED → CHECKED_IN; không cho CHECKED_IN nếu chưa được duyệt hoặc sai khung thời gian.
Sự kiện	DRAFT, OPEN, FULL, CLOSED, CANCELLED, COMPLETED	Chỉ OPEN nhận đăng ký; thay đổi sức chứa phải kiểm tra số đăng ký đang chiếm chỗ; ẩn/xóa mềm không được phá lịch sử.
Trusted Device	APPROVED, REVOKED, EXPIRED	REVOKED/EXPIRED không được khôi phục tự động chỉ vì cookie còn tồn tại; phải xác thực và xin duyệt lại.
Admin Session	PENDING_APPROVAL, ACTIVE, KICKED, EXPIRED, REVOKED	KICKED/EXPIRED/REVOKED không được gọi vào endpoint bảo vệ; session đăng nhập không đồng nghĩa với Primary.

J.6.3. Công thức thống kê Dashboard

Đề xuất định nghĩa thống nhất: tỷ lệ điểm danh của một sự kiện = số đăng ký đã được duyệt và có điểm danh / tổng số đăng ký đã được duyệt × 100%. Loại đăng ký chờ duyệt, bị từ chối, đã hủy khỏi mẫu số. Nếu tổng đăng ký đã duyệt bằng 0 thì hiển thị 0%, không chia cho 0. Tỷ lệ toàn CLB nên tính bằng tổng lượt điểm danh chia tổng lượt đăng ký đã duyệt trong kỳ, không lấy trung bình đơn giản các tỷ lệ sự kiện nếu quy mô sự kiện khác nhau.

J.7. Thiết kế an toàn cho Primary Admin, Trusted Device và Remember Me

Ba cơ chế này phải được thiết kế tách biệt. Trusted Device xác nhận thiết bị từng được Primary phê duyệt; Remember Me hỗ trợ duy trì đăng nhập; Primary Session là quyền độc quyền quản lý thiết bị và xem Audit Log. Không coi riêng sự hiện diện của cookie thiết bị là bằng chứng đủ để cấp quyền Admin.

J.7.1. Quy trình đăng nhập đề xuất

- Đăng nhập bằng email/mật khẩu hợp lệ hoặc Remember Me token còn hạn, chưa thu hồi và được xác minh ở máy chủ. Token được lưu ở CSDL dưới dạng hash; không lưu/ghi log token thô.
- Nếu thiết bị chưa tin cậy: tạo yêu cầu PENDING_APPROVAL, chỉ cho xem trang chờ và đăng xuất; không cho truy cập chức năng quản trị cho đến khi Primary phê duyệt.
- Khi Primary phê duyệt: tạo Trusted Device token ngẫu nhiên đủ mạnh, lưu hash ở DB; trả token thô một lần qua cookie Secure + HttpOnly + SameSite phù hợp; thiết bị mới thành phiên ACTIVE không phải Primary trừ khi có quy trình chuyển quyền riêng.
- Khi tài khoản đăng nhập trên thiết bị đã tin cậy: vẫn xác thực tài khoản (mật khẩu hoặc Remember Me hợp lệ), sau đó có thể bỏ qua bước xin duyệt thiết bị. Thiết bị tin cậy không tự động được quyền Primary.
- Khi kickout: cập nhật session record thành KICKED trong transaction; request bảo vệ kế tiếp phải bị từ chối, hủy HttpSession và yêu cầu đăng nhập. Khi thu hồi thiết bị: đánh dấu REVOKED, vô hiệu token và kickout mọi phiên còn hiệu lực gắn với device_id.
- Chỉ một phiên được đặt is_primary = true. Cần khóa hàng điều khiển (ví dụ admin_control SELECT ... FOR UPDATE) trong transaction khi cấp/chuyển quyền; không chỉ kiểm tra bằng SELECT thông thường vì hai request đồng thời có thể cùng trở thành Primary.

- Không cho Primary kickout chính phiên đang thao tác bằng cùng nút "Kickout ngay"; cung cấp thao tác "Đăng xuất" hoặc "Chuyển quyền Primary" riêng để tránh tự khóa hệ thống. Quy trình khôi phục khi Primary mất thiết bị phải yêu cầu xác thực tăng cường và ghi Audit Log.

J.7.2. Cookie, timeout và heartbeat

- Cookie xác thực dài hạn phải là opaque random token, lưu hash trên máy chủ; rotate token sau khi sử dụng; giới hạn tuổi tối đa 30 ngày theo yêu cầu dự án; hỗ trợ thu hồi phía máy chủ và chống replay. Không dùng IP/User-Agent làm yếu tố xác thực duy nhất vì hai giá trị có thể thay đổi hoặc bị giả mạo.
- Bật Secure trên staging/production chạy HTTPS; HttpOnly; SameSite=Lax hoặc Strict theo luồng điều hướng; Path và Max-Age tối thiểu cần thiết. Cookie Secure sẽ không vận hành như mong đợi trên môi trường HTTP thông thường, vì vậy phải xác định rõ HTTPS cho staging hoặc dùng cấu hình riêng chỉ dành cho local development.
- Heartbeat 5 phút chỉ nên chạy khi tab đang hiển thị và người dùng còn hoạt động; không dùng heartbeat để giữ session vô thời hạn. Cần có idle timeout, absolute session lifetime, logout/revoke và yêu cầu đăng nhập lại cho thao tác nhạy cảm. Có thể đặt mục tiêu idle timeout 30 phút và giới hạn tuyệt đối 8 giờ làm giá trị khởi đầu để nhóm kiểm thử/chốt theo yêu cầu môn học.
- Để tránh CSRF, mọi thao tác thay đổi trạng thái (duyệt, kickout, thu hồi, cập nhật dữ liệu) phải dùng POST/PUT tương ứng, CSRF token và kiểm tra quyền phía máy chủ. Không thực hiện thao tác nhạy cảm qua GET.
- Audit log không nên lưu raw HttpSession ID, raw device token, cookie, mật khẩu hoặc dữ liệu xác thực. Dùng internal session UUID và/hoặc hash định danh để truy vết; chỉ lưu IP/User-Agent khi cần và giới hạn người được đọc.

J.7.3. Đảm bảo Audit Log thực sự append-only

Chỉ có AuditLogDAO với phương thức insertLog() và getLogs() là điểm khởi đầu tốt nhưng chưa đủ để bảo đảm bất biến ở tầng CSDL. Bổ sung tài khoản DB riêng cho ứng dụng chỉ có quyền INSERT và SELECT trên audit_logs, không cấp UPDATE/DELETE; không tạo endpoint sửa/xóa; mọi lần đọc log đều được server kiểm tra Primary Session. Ghi log trong cùng transaction với thao tác nhạy cảm hoặc có cơ chế đảm bảo không mất dấu. Không ghi token, password, session cookie hoặc nội dung nhạy cảm đầy đủ vào log.

J.8. Danh sách màn hình và đường dẫn cần có để web thành ứng dụng dùng được

Danh sách dưới đây là bản đồ giao diện đề xuất để BA/Dev đối chiếu với giao diện đang có. Có thể đổi tên URL theo quy ước nhóm, nhưng cần giữ cùng một bảng ánh xạ từ UI → Servlet → Service → DAO.

Nhóm màn hình	Nội dung tối thiểu	URL gợi ý
Công khai	Trang chủ/danh sách sự kiện, chi tiết sự kiện, tìm kiếm/lọc, lịch tháng/tuần.	/, /events, /events/{id}, /calendar
Tài khoản	Đăng ký, đăng nhập, đăng xuất, hồ sơ, đổi mật khẩu, quên mật khẩu/khôi phục tài khoản.	/register, /login, /logout, /profile, /change-password, /forgot-password
Hội viên	Gửi đơn gia nhập, xem trạng thái/lịch sử xử lý; đăng ký/hủy sự kiện; lịch sử tham gia; QR check-in; thông báo; phản hồi.	/membership-requests, /my/registrations, /my/attendance, /checkin, /my/notifications
Quản trị CLB	Dashboard; CRUD hội viên/sự kiện; duyệt đơn gia nhập và đăng ký; điểm danh thủ công; bài viết/thông báo; Ban/Bộ phận, Chức vụ, Nhiệm kỳ, phân công; báo cáo.	/admin/dashboard, /admin/members, /admin/events, /admin/membership-requests, /admin/registrations, /admin/attendance, /admin/organization, /admin/reports
Quản lý phiên Primary	Xem phiên đang hoạt động/đang chờ; duyệt hoặc từ chối thiết bị; kickout; thu hồi thiết bị tin cậy; Audit Log.	/admin/sessions, /admin/audit-logs, /admin/devices
Hệ thống/kiểm tra	Health check; trang lỗi 403/404/500; trạng thái phiên; xử lý upload; kiểm tra kết nối DB có kiểm soát.	/health, /error/403, /error/404, /error/500

Trạng thái giao diện cần bổ sung cho mỗi trang: đang tải (loading), không có dữ liệu (empty state), lỗi kết nối/lỗi máy chủ, không đủ quyền, biểu mẫu lỗi theo từng trường và thông báo thành công/thất bại. Danh sách quản trị cần tìm kiếm, lọc, phân trang; biểu mẫu phải giữ dữ liệu hợp lệ khi báo lỗi để người dùng không phải nhập lại.

J.9. Yêu cầu phi chức năng và tiêu chí nghiệm thu đề xuất

Các số dưới đây là mục tiêu nghiệm thu đề xuất cho bản demo/học phần, không phải số liệu hiệu năng đã đo. Nhóm cần thử trên môi trường staging và điều chỉnh nếu cấu hình máy thực tế khác nhau.

Mã / tiêu chí	Điều kiện nghiệm thu đề xuất
NFR-01 Bảo mật	Mật khẩu lưu bằng hash phù hợp (BCrypt/Argon2id), không plaintext; session ID đổi sau đăng nhập; rate-limit/khóa tạm khi nhiều lần đăng nhập sai; kiểm soát quyền server-side cho mọi URL admin.
NFR-02 Nhất quán dữ liệu	Không tạo đăng ký trùng; không vượt sức chứa khi hai người tranh suất cuối; không tạo hai Primary Session đồng thời; các chuyển trạng thái có transaction và kiểm tra điều kiện.
NFR-03 Hiệu năng demo	Mục tiêu ban đầu: 95% request đọc danh sách sự kiện/hội viên dưới 2,5 giây với bộ dữ liệu demo và tối đa 50 phiên truy cập giả lập; ghi rõ máy thử và dữ liệu khi báo cáo.
NFR-04 Giao diện đáp ứng	Các màn hình cốt lõi dùng được ở chiều rộng 360 px trở lên và trên desktop; không tràn ngang ở bảng quan trọng; form có label và báo lỗi dễ hiểu.
NFR-05 Khả dụng và lỗi	Có trang 403/404/500 thân thiện; không lộ stack trace/SQL/password cho người dùng; khi DB không kết nối thì báo lỗi có kiểm soát và ghi log kỹ thuật.
NFR-06 Sao lưu/khôi phục	Sao lưu CSDL trước thay đổi schema và trước demo quan trọng; có quy trình restore thử trên DB riêng; giữ lịch sử backup theo chính sách nhóm.
NFR-07 Triển khai	Build WAR tái lập được bằng mvn clean verify/package; sau CD phải có health check và smoke test; khi thất bại phải giữ hoặc khôi phục bản WAR trước đó.
NFR-08 Riêng tư dữ liệu	Chỉ lưu trường thông tin cần thiết; hội viên chỉ xem dữ liệu của mình; hạn chế quyền tải báo cáo; không đưa dữ liệu cá nhân thật vào repository hoặc test fixture công khai.
NFR-09 Khả năng bảo trì	Mỗi nghiệp vụ quan trọng có Service riêng, DAO không chứa logic giao diện; lỗi và chuyển trạng thái được ghi rõ; README mô tả cài đặt, cấu hình, build, chạy và reset dữ liệu.
NFR-10 Khả năng tiếp cận	Điều hướng bàn phím cơ bản, nhãn form, focus nhìn thấy được, trạng thái không chỉ biểu đạt bằng màu sắc; ảnh nội dung có alt text phù hợp.

J.10. Kiểm thử bổ sung cho phiên Admin và tính toàn vẹn dữ liệu

Các test case TC45-TC61 dưới đây được đề xuất bổ sung sau TC44 để phủ các rủi ro mới từ phần Single Active Admin, Trusted Device, Remember Me và xử lý đồng thời. Mặc định "Chưa chạy"; chỉ chuyển thành Đạt/Không đạt sau khi thực thi thật trên Local hoặc staging và lưu bằng chứng.

Mã TC	Kịch bản	Kết quả mong đợi	Trạng thái ban đầu
TC45	Hai request đồng thời cùng xin quyền Primary	Chỉ một phiên trở thành ACTIVE Primary; phiên còn lại bị từ chối hoặc chờ; không tồn tại hai primary trong DB.	Chưa chạy
TC46	Thiết bị mới đăng nhập nhưng chưa được duyệt	Tạo yêu cầu PENDING_APPROVAL; không truy cập dashboard/API quản trị; hiện trang chờ duyệt.	Chưa chạy
TC47	Primary phê duyệt thiết bị mới	Trusted Device được tạo; token thô chỉ trả qua cookie bảo mật; audit ghi nhận thiết bị và người duyệt nhưng không chứa token thô.	Chưa chạy
TC48	Thiết bị APPROVED đăng nhập lại bằng xác thực hợp lệ	Được bỏ qua bước xin duyệt thiết bị nhưng không tự động trở thành Primary; quyền còn lại đúng role.	Chưa chạy
TC49	Thu hồi trusted device đang có phiên hoạt động	Thiết bị chuyển REVOKED; các phiên gắn thiết bị bị vô hiệu; request kế tiếp bị từ chối và yêu cầu xác thực/duyệt lại.	Chưa chạy
TC50	Primary kickout một phiên Admin khác	Phiên mục tiêu có status KICKED; request kế tiếp invalidate HttpSession và chuyển về login với thông báo phù hợp.	Chưa chạy
TC51	Phiên Admin không phải Primary truy cập Audit Log	Bị từ chối ở server (403/redirect); không chỉ ẩn menu trên giao diện.	Chưa chạy
TC52	Thử gọi API sửa/xóa audit_logs qua ứng dụng	Không có endpoint update/delete; yêu cầu trái phép bị từ chối; quyền DB của ứng dụng không cho UPDATE/DELETE.	Chưa chạy
TC53	Remember Me token hết hạn/đã thu hồi	Không tự đăng nhập; yêu cầu đăng nhập lại; token cũ không khôi phục session.	Chưa chạy
TC54	Phát lại Remember Me token cũ sau khi rotate	Token cũ bị từ chối; chỉ token mới hợp lệ; sự kiện bất thường được ghi log nếu phù hợp.	Chưa chạy
TC55	Gửi POST kickout/approve thiếu CSRF token	Request bị chặn; trạng thái phiên/thiết bị không thay đổi.	Chưa chạy
TC56	Hội viên hoặc Trưởng ban gọi trực tiếp URL Admin	Server từ chối theo role; không lộ dữ liệu, không thay đổi dữ liệu.	Chưa chạy
TC57	Hai hội viên tranh suất cuối của cùng sự kiện	Chỉ một request thành công; số chỗ không âm; đăng ký còn lại nhận thông báo hết chỗ.	Chưa chạy
TC58	Một hội viên gửi hai request đăng ký cùng sự kiện cùng lúc	Chỉ có một bản ghi active nhờ kiểm tra Service và UNIQUE constraint; không trừ chỗ hai lần.	Chưa chạy
TC59	Token QR hết hạn, sai sự kiện hoặc đã dùng điểm danh	Không ghi nhận điểm danh; trạng thái registration/attendance không đổi; có thông báo phù hợp.	Chưa chạy

Mã TC	Kịch bản	Kết quả mong đợi	Trạng thái ban đầu
TC60	Tạo tài khoản với email trùng và dữ liệu nhập độc hại	Unique constraint chặn email trùng; payload SQL/XSS không được thực thi hoặc hiển thị như HTML.	Chưa chạy
TC61	Khôi phục backup CSDL lên môi trường kiểm tra	Khôi phục thành công; khóa ngoại và dữ liệu lịch sử được bảo toàn; không ghi đè nhầm CSDL đang demo.	Chưa chạy

Sau khi bổ sung 17 test case, tổng Test Plan thiết kế sẽ là 61 test case (44 hiện có + 17 đề xuất). Đây là tổng số kịch bản trong kế hoạch, không phải số đã thực thi hoặc số đạt. Báo cáo cuối cùng phải tách rõ "đã thiết kế", "đã chạy", "đạt", "không đạt", "bị chặn" và "chưa chạy".

J.11. CI/CD và tiêu chuẩn đóng gói ứng dụng có thể chạy được

J.11.1. Các điểm cần bổ sung trong workflow

- Workflow CI nên chạy trên Pull Request vào develop/main và push lên các nhánh cần kiểm tra; pipeline có bước clean verify hoặc test, xuất Surefire Report và fail khi test thất bại. Đảm bảo tên check trong Branch Protection khớp chính xác với tên job/check thực tế.
- Workflow CD chỉ chạy từ nhánh main đã được bảo vệ, dùng self-hosted runner riêng cho deploy và không thực thi mã PR không tin cậy trên runner có quyền ghi vào máy Tomcat. Hạn chế quyền GITHUB_TOKEN theo nguyên tắc tối thiểu; secrets chỉ được đưa vào job cần dùng.
- Thêm bước xác nhận TOMCAT_HOME/đường dẫn WAR tồn tại, sao lưu WAR hiện tại, triển khai bản mới, đợi Tomcat ổn định, gọi /uniclub/health, chạy smoke test trang đăng nhập/danh sách sự kiện. Nếu thất bại thì rollback WAR đã lưu và đánh dấu workflow FAIL.
- Có thể thêm dependency vulnerability scan và Checkstyle/SpotBugs, nhưng tài liệu phải phân biệt rõ bước đã tích hợp và bước mới ở mức thiết kế. Không ghi "hoàn thành" nếu workflow chưa thực sự chạy thành công trong repository.
- Bật HTTPS cho môi trường kiểm thử các cookie Secure/Remember Me. Nếu staging chỉ chạy HTTP, cần ghi rõ giới hạn môi trường và không lấy kết quả thử cookie trên HTTP làm xác nhận cho môi trường bảo mật.

J.11.2. Checklist cấu trúc source code

Cấu trúc gợi ý để người khác clone repository và chạy dự án mà không phải đoán file nằm ở đâu:

```
UniClub/
├── pom.xml
├── README.md
├── .gitignore
├── .github/workflows/
│   ├── ci.yml
│   └── cd.yml
├── database/
│   ├── schema.sql
│   └── data.sql
├── src/main/java/com/uniclub/
│   ├── config/        (DatabaseConnection, cấu hình)
│   ├── model/         (NguoiDung, SuKien, DangKyThamGia, ...)
│   ├── dao/           (DAO và truy vấn PreparedStatement)
│   ├── service/       (nghiệp vụ và transaction)
│   ├── controller/    (Servlet)
│   ├── filter/        (AuthFilter, SingleActiveSessionFilter, CSRF)
│   └── util/          (hash mật khẩu, token, validate, export)
├── src/main/webapp/
│   ├── assets/css/ assets/js/ assets/images/
│   ├── WEB-INF/views/ (JSP không truy cập trực tiếp)
│   └── WEB-INF/web.xml (nếu dự án dùng cấu hình deployment descriptor)
└── src/test/java/com/uniclub/ (JUnit 5, Mockito, test Service/DAO)
```

- README phải có phiên bản JDK, Maven, Tomcat và MySQL; các bước tạo database, import schema.sql/data.sql, cấu hình kết nối không chứa secret, chạy bằng NetBeans và chạy bằng Maven; địa chỉ URL chuẩn; cách tạo tài khoản demo an toàn; cách chạy test và cách deploy/rollback.
- schema.sql phải tạo được CSDL từ trạng thái rỗng; data.sql chỉ dùng dữ liệu giả. Có thể thêm migration script khi đổi schema; không sửa tay CSDL trên staging mà không có lịch sử thay đổi.

- Trước khi nghiệm thu, chạy thử trên máy sạch hoặc thư mục clone mới: tạo DB → cấu hình → mvn clean verify → deploy WAR → mở URL → đăng nhập bằng từng role → thử luồng chính → kiểm tra Health Check. Đây là bằng chứng "runnable", khác với việc chỉ có code trong Word.

J.12. Definition of Done - tiêu chí hoàn thành ứng dụng

Chỉ coi một chức năng là hoàn thành khi đáp ứng đủ các tiêu chí áp dụng bên dưới; "đã có giao diện" hoặc "đã viết code" chưa đồng nghĩa với "đã hoàn thành".

- Có User Story/Use Case và quy tắc trạng thái đã thống nhất; có validation phía server và thông báo lỗi dễ hiểu.
- Đã triển khai đủ luồng thành công, luồng lỗi, quyền truy cập và thao tác dữ liệu; không chỉ làm giao diện tĩnh.
- Có schema/khóa ngoại/ràng buộc/index phù hợp; thao tác cập nhật quan trọng có transaction và kiểm tra dữ liệu đồng thời.
- Có test case liên quan; test đã chạy và ghi kết quả thực tế/bằng chứng; không tự đánh dấu Pass khi chưa chạy.
- Code đã qua review ít nhất một thành viên khác; CI PASS; không đưa mật khẩu, token hoặc file cấu hình thật lên Git.
- Giao diện được kiểm tra trên desktop và màn hình điện thoại; trạng thái loading/empty/error/unauthorized được xử lý.
- Nếu chức năng được đưa lên staging, CD có health check/smoke test; có phương án rollback và dữ liệu backup.
- Tài liệu cập nhật tương ứng: User Story/UC, Class/ERD, Test Plan/Report, README và kịch bản demo cùng một quy ước tên.

J.13. Thứ tự thực hiện khuyến nghị

Giai đoạn	Công việc ưu tiên
Bước 1 - Chốt đặc tả (P0)	Thống nhất ID UC, vai trò nhóm, lịch Sprint, role vs Primary Session, trạng thái đăng ký/phiên, tên bảng và context path.
Bước 2 - Nền tảng chạy được (P0)	Khóa Java/Tomcat/Jakarta Servlet; tạo schema.sql/data.sql; cấu hình DB ngoài source; clone mới phải build/deploy được.
Bước 3 - Nghiệp vụ an toàn (P0)	Hoàn thiện đăng nhập/phân quyền, transaction đặt chỗ, luồng đơn gia nhập, session Primary, kickout, thu hồi Trusted Device và append-only Audit Log.
Bước 4 - UI và trải nghiệm (P1)	Bổ sung các màn hình còn thiếu, trạng thái rỗng/lỗi, tìm kiếm/phân trang, thông báo và responsive.
Bước 5 - Kiểm thử và CI/CD (P0/P1)	Chạy 44 test case hiện có và 17 test bổ sung theo phạm vi triển khai; ghi kết quả thực tế; thêm health check, smoke test và rollback.
Bước 6 - Nghiệm thu cuối	Đối chiếu Done Checklist, chạy demo trên staging, chuẩn bị dữ liệu giả, video dự phòng và Q&A.

J.14. Kết luận rà soát

Hồ sơ UniClub đã có nhiều nội dung nền tảng, vì vậy không cần viết lại từ đầu. Phần cần làm tiếp là thống nhất các điểm mâu thuẫn, cụ thể hóa những yêu cầu hiện mới ở mức mô tả và chuyển chúng thành ràng buộc dữ liệu, quyền truy cập, test case và tiêu chí nghiệm thu có thể kiểm chứng. Nếu nhóm xử lý các mục P0 trước, sau đó hoàn thiện UI, kiểm thử và CI/CD, hồ sơ sẽ phản ánh sát hơn một ứng dụng web có thể chạy và bàn giao, thay vì chỉ là danh sách tính năng.

Lưu ý khi sử dụng phụ lục: giữ nguyên phần hồ sơ cũ; dùng phụ lục này như danh sách bổ sung và quyết định thiết kế. Khi nhóm thực hiện thay đổi thật trong code, cập nhật lại tài liệu liên quan và chỉ ghi nhận trạng thái hoàn thành dựa trên bằng chứng chạy thực tế.

Kết thúc phụ lục rà soát chuyên gia - nội dung bổ sung, không thay thế hồ sơ gốc.